Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Герасимовой Дарьи Николаевны
(фамилия, имя, отчество обучающегося)

Тема: Программно-технический комплекс риск-моделирования кибератак: информационное и методическое обеспечение

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 82 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (подпись) (А.Г.Остапенко) (инициалы, фамилия)

Руководитель _____ (подпись) (Л.В. Паринова) (инициалы, фамилия)

Консультанты:

по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

Обучающийся _____ (подпись) Д.Н. Герасимова (инициалы, фамилия)

« 02 » 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 Информационная безопасность автоматизированных систем
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Герасимовой Дарье Николаевне
фамилия, имя, отчество

1. Тема: Программно-технический комплекс риск-моделирования кибератак: информационное и методическое обеспечение

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ № 01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.2025

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1 Исследование информационного обеспечения риск-моделирования кибератак
Перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2 Разработка методического обеспечения риск-моделирования кибератак

Раздел 3 Сценарии рисков реализации угроз

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03-22.05
2	Исследование информационного обеспечения риск-моделирования кибератак	22.03-22.05
3	Разработка методического обеспечения риск-моделирования кибератак	23.05-31.05
4	Сценарии рисков реализации киберугроз	01.06-24.06
5	Заключение	25.06-02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.2025

Задание принял к исполнению 22.03.2025
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающейся Герасимовой Дарьи Николаевны

Тема ВКР: Программно-технический комплекс риск-моделирования кибератак: информационное и методическое обеспечение

Характеристика выпускной квалификационной работы

Актуальность исследования: рост киберугроз требует своевременного обнаружения, прогнозирования и оценки потенциального ущерба от атак. Существующие методы анализа рисков, опирающиеся на базы уязвимостей и калькуляторы, не всегда обеспечивают комплексный подход. Ключевым недостатком аналогов является отсутствие автоматизированной оценки рисков применительно к множественным кибератакам, что критически важно для эффективного управления рисками.

Задачи, решаемые в ВКР: разработка информационного обеспечения риск-моделирования кибератак, а именно классификация кибератак, исследование интернет-ресурсов данных и установление взаимосвязи между ними для описания процессов реализации кибератак, разработка методического обеспечения риск-моделирования кибератак различного уровня с учетом динамики развития атакующих сценариев, разработка модели сценарного туннеля кибератак, позволяющей анализировать последовательность реализуемых техник.

Структура ВКР

Введение

Раздел 1 Исследование информационного обеспечения риск-моделирования кибератак

Раздел 2 Разработка методического обеспечения риск-моделирования кибератак

Раздел 3 Сценарии рисков реализации угроз

Заключение

Список литературы

Приложение А

Краткая характеристика полученных результатов

1.Разработанно информационное обеспечение, представляет сформированную базу данных, которая в полной мере служит основой для анализа кибератак.

2. Разработано методическое обеспечение риск-моделирования, позволяющее значительно повысить устойчивость автоматизированных информационных систем к кибератакам, обеспечивая более точное прогнозирование и предотвращение потенциальных угроз.

3. Разработанная модель сценарного туннеля кибератак, позволяет анализировать последовательность реализуемых техник в рамках единого атакующего сценария.

Автор ВКР_____ Герасимова Дарья Николаевна
(подпись)

СОДЕРЖАНИЕ

Введение 7
1 Исследование информационного обеспечения риск-моделирования кибератак 11
1.1 Понятие и классификация кибератак 11
1.2 Исследование интернет-ресурсов данных о кибератаках в контексте осуществления риск-моделирования 17
1.3 Установление взаимосвязей между базами данных для описания процессов реализации кибератак 28
1.4 Средства калькуляции рисков кибератак 31
2 Разработка методического обеспечения риск-моделирования кибератак 43
2.1 Методическое обеспечение моделирования рисков единичных кибератак 44
2.2 Методическое обеспечение для моделирования рисков многократных кибератак 48
2.3 Методическое обеспечение для моделирования рисков многовекторных кибератак 61
3 Сценарии рисков реализации киберугроз 63
3.1 Связь техника – уязвимость в процессе осуществления кибератак 63
3.2 Сценарии реализуемых техник кибератак 64
3.3 Перспективные направления управления рисками современных кибератак 67
Заключение 69
Список литературы 71
Приложение А 82

Введение

Актуальность защиты киберпространства стабильно растет, так как только в 2024 году проанализированы 405 тысяч кибератак, на различные отрасли деятельности как сообщает компания «Код Безопасности». Проведенное исследование выявило неравномерное распределение киберинцидентов по отраслям экономики. Наибольшая концентрация атак наблюдалась в следующих секторах: финансовый (118 случаев, 29% от общего количества), государственный (112 случаев, 28%), здравоохранение (66 случаев, 16%), образование (51 случай, 13%), а также ИТ и телекоммуникации (49 случаев, 9%). Следует отметить, что часть инцидентов имела межотраслевой характер, затрагивая одновременно несколько сфер деятельности.

Динамический анализ показал рост количества инцидентов на 15% по сравнению с аналогичным периодом 2023 года, при этом зафиксировано незначительное снижение (на 4%) по сравнению с предыдущим кварталом текущего года.

Основные векторы атак распределились следующим образом:

- Вредоносное ПО доминировало в атаках как на организации (65% успешных инцидентов), так и на частных лиц (72%).

- Методы социальной инженерии составили 92% атак на частных пользователей и 50% - на корпоративный сектор.

- Утечки конфиденциальных данных зафиксированы в 52% успешных атак на организации и 77% - на физических лиц.

Особого внимания заслуживает увеличение на 5% случаев нарушения основной деятельности организаций, что коррелирует с возросшей активностью групп, специализирующихся на программах-вымогателях. Данная статистика свидетельствует о необходимости пересмотра существующих подходов к кибербезопасности, особенно в наиболее уязвимых отраслях.

Только 40% крупных предприятий имеют выделенные отделы информационной безопасности, тогда как в 55% организаций эти обязанности выполняют ИТ-специалисты. Однако 83% компаний намерены перевести мониторинг киберугроз на

аутсорсинг в специализированные центры [81].

В условиях растущего числа киберугроз, критически важным становится их своевременное обнаружение атак, их прогнозирование, а также оценка потенциального ущерба. Существующие методы анализа рисков, основанные на базах данных уязвимостей [16-21] и специализированных калькуляторах [22-29], безусловно полезны, но зачастую не могут обеспечить целостный подход.

В информационном и методическом обеспечении которые представлены в аналогах [10-26], отсутствует необходимая автоматизация оценки и рисков для множественных кибератак, которая необходима для эффективного управления рисками.

Одной из ключевых проблем является отсутствие единых методик позволяющих оценивать не только единичные угрозы, но и комплексные сценарии атак, включая многократные и многовекторные вторжения. Кроме того, большинство моделей не учитывают динамику развития угроз, что снижает прогнозирование.

Актуальность темы исследования обусловлена наличием противоречий между:

- богатой информационной базой о киберугорзах в теории и ограниченными возможностями ее эффективного использования для построения точных практико-ориентированных риск-моделей на практике;

-требованиями результативного управления рисками кибератак и ограниченными возможностями уже существующих методик, зачастую не учитывающих всю сложность современных угроз.

-необходимостью внедрения программно-технических комплексов в существующие системы информационной безопасности и недостаточной совместимостью таких решений, что затрудняет их эффективное применение.

Объектом исследования являются автоматизированные информационные системы (АИС), являющиеся основой цифровой инфраструктуры большинства организаций, и подверженные широкому спектру угроз.

Предметом исследования являются методы, алгоритмы, позволяющие не только оценивать вероятность кибератак, но и моделировать их последствия с учётом различных факторов таких как критичность ресурсов, возможные векторы атак и

степень уязвимости системы.

Целью исследования является повышение защищенности АИС на основе создание информационного и методического обеспечения для программно-технического комплекса, обеспечивающего моделирование кибератак.

Для достижения поставленной цели необходимо решить следующие задачи:

- исследовать информационное обеспечение риск-моделирования кибератак, а именно, классифицировать кибератаки, исследовать интернет-ресурсы данных о кибератаках в контексте осуществления риск-моделирования, установить взаимосвязи между базами данных для описания процессов реализации кибератак;

-разработать методическое обеспечение риск-моделирования кибератак различного уровня сложности (единичных, многократных и многовекторных), включающее формализованные подходы к оценке вероятности, критичности и цепочек воздействия реализации угроз с учетом динамики развития атакующих сценариев;

-разработать модель сценарного туннеля кибератак, позволяющую анализировать последовательность реализуемых техник в рамках единого атакующего сценария, с учётом условий перехода между этапами.

Результаты, выносимые на защиту, имеют следующую новизну:

- предложенное информационное, методическое обеспечение, технического комплекса риск-моделирования, в отличии от существующих аналогов описывает методы автоматизированной оценки риска единичных, многократных и многовекторных кибератак, а также метрики для их калькуляции;

- впервые предлагается методика управления рисками для множественных кибератак в защищаемых автоматизированных системах, доведенная до автоматизации;

- впервые разработана модель сценарного туннеля кибератак, представляющая новый подход к анализу последовательности атакующих техник, которая преодолевает ограничения существующих статических моделей за счет динамического представления развития киберугроз.

Практическая ценность полученных результатов состоит в следующем:

- разработанное информационное обеспечение, представляет сформированную базу данных, которая в полной мере служит основой для анализа кибератак;

- разработанное методическое обеспечение риск-моделирования, позволяют значительно повысить устойчивость автоматизированных информационных систем к кибератакам, обеспечивая более точное прогнозирование и предотвращение потенциальных угроз;

- разработанный программно-технический комплекс может стать основой для формирования единых стандартов в области риск-моделирования кибератак, что облегчит внедрение и использование аналогичных решений в различных отраслях.

Теоретическая значимость результатов исследования определяется следующим образом:

- полученные результаты включают в себя разработку технологических моделей и алгоритмов, которые могут послужить основой для дальнейшего научного изучения и совершенствования технологий риск-моделирования;

- работа закладывает фундамент для последующих исследований в области автоматизации процессов оценки и прогнозирования киберугроз, открывая перспективы для более глубокого понимания и борьбы с кибератаками технологий риск-моделирования

- результаты исследования обогащают методологическую базу кибербезопасности, предоставляя новые принципы и методы для анализа и оценки рисков, что способствует повышению качества научных исследований и образовательных программ в этой области.

1 Исследование информационного обеспечения риск-моделирования кибератак

Благодаря интенсивному развитию арсенала компьютерных атак и эксплуатирующих ими уязвимостей [9], за последнее десятилетие киберпространство фактически превратилось в поле битвы [7], где спецслужбы враждующих государств и криминальные структуры неустанно противоборствуют за достижение информационного превосходства. В целях отслеживания динамики этого процесса созданы и успешно функционируют интернет-ресурсы [10-26], без которых сегодня уже немыслима работа любого специалиста по защите информации.

Вместе с тем, по прежнему актуальной остаётся цель создания аналитических инструментов [7,9], позволяющих моделировать кибератаки и предсказывать их последствия. В этом отношении представляется перспективным использование и развитие аппарата оценки и регулирования рисков [9], внедрение которого особенно актуально в отношении множественных атак, отличающихся повышенной сложностью как в описании, так и в части противодействия им.

1.1 Понятие и классификация кибератак

На сегодняшний день современный мир стремительно движется в тотальной цифровизации во всех сферах деятельности человека. Везде используются сложные информационные системы, начиная финансовыми операциями и заканчивая управлением критической инфраструктурой. Соответственно угроза киберпреступности растет, за счет цифровой трансформации.

Кибератака – это целенаправленное злонамеренное воздействие на информационные системы, сети, устройства или данные с целью их повреждения, получения конфиденциальных данных, или ограничения доступа к ним [8,9].

Для совершения кибератаки, злоумышленники ищут уязвимости в информационных системах, то есть ошибки в коде, недостатки в конфигурации или устаревшие версии программ. Для проведения атак используются не только программные или аппаратные уязвимости, но и социальная инженерия –

манипуляции для получения конфиденциальной информации путем обмана пользователя.

Кибератаки последних лет показывают свой уникальный уровень сложности. Особую тревогу вызывает появление новых видов угроз, которые сочетают технические уязвимости с искусственным интеллектом. В условиях постоянно меняющегося ландшафта угроз актуальность приобретает задача их классификации.

Представляется целесообразным предложить следующую классификацию кибератак (рис.1)



Рисунок 1 – Обобщенная классификация кибератак

Простейшим вариантом следует считать одиночные атаки, где реализуется одноразовая попытка вторжения в атакуемую систему с помощью единственного шаблона. Такие атаки зачастую используются на начальных этапах разведки. Их ключевой особенностью является минимальная ресурсоемкость и малая заметность, соответственно, что делает их очень полярным средством для поверхностного тестирования защитных механизмов. Но эффективность таких атак существенно ограничена базовыми мерами безопасности, и могут использоваться либо неопытными злоумышленниками, либо они могут использоваться в составе более масштабных и сложных атак, в качестве начального этапа. При множественных

атаках такая попытка осуществляется избранным шаблоном несколько раз, что повышает шанс на успех, но также увеличивает вероятность обнаружения. Их отличием заключается в способности адаптации. Каждая попытка может модифицироваться на основе обратной связи от защитных систем. Такие атаки чаще всего реализуют постепенное расширение возможностей, когда первоначально полученный ограниченный доступ последовательно расширяется через серию однонаправленных воздействий. При этом сохраняется баланс между агрессивностью воздействия и риском преждевременного обнаружения, что требует от злоумышленника регулирования временных интервалов между попытками. Характерным примером в данном случае является многократная атака, когда последовательно реализуется серия попыток вторжения одним и тем же шаблоном.

Многовекторные атаки, в отличии от рассмотренных разновидностей, нацелены на множество объектов, атакуемых в любой последовательности или синхронно. Это делает их более сложными для отражения, поскольку специалистам приходится реагировать на угрозы одновременно по нескольким направлениям. Особенностью таких атак является необходимость сложной координации между различными компонентами эксплуатации, что подразумевает под собой наличие продвинутой инфраструктуры управления. При этом векторы атак могут быть разными по своей природе, от простых до довольно-таки изощренных, что создает серьезные трудности их обнаружения для систем мониторинга. Если злоумышленник при попытке вторжения использует различные шаблоны, то такую атаку можно назвать комбинированной, комбинирующей разнообразные средства для достижения большого ущерба. Подобные комбинированные удары дезориентируют силы защиты и являются особенно опасными. Такие атаки зачастую используют принцип, при котором одни компоненты атаки служат для отвлечения внимания, а другие – для реализации основного удара. Сложность таких атак заключается в том, что злоумышленник могут гибко менять тактику, адаптируя свою атаку во время её проведения.

Наиболее изощрёнными следует считать комплексные атаки, где применение средств вторжения может быть рассредоточено как в пространстве, так и во времени.

Фактически это целая информационная операция, которая включает этапы разведки, внедрения, закрепления в системе и выполнения конечных целей. Исполнение таких чаще всего предполагает создание скрытых точек опоры в атакуемой системе, активизирующиеся только при наступлении определенных условий. Особенностью комплексных атак является способностью адаптации методов проникновения под изменяющиеся условия системы. Зачастую такие атаки координируются группами злоумышленников могут длится месяцами, оставаясь незамеченными.

Представленная (рис.1) классификация с успехом может быть развита с учетом спецификации защищаемых систем и целей, преследуемых злоумышленниками. С переходом в детализации от шаблонов атаки к реализующим её тактикам классификация станет ещё более емкой и возможно даже многомерной. Однако это не отменяет необходимости моделирования всех необходимых для рассмотрения разновидностей вторжения, что принципиально необходимо для развития теории обеспечения кибербезопасности.

Проиллюстрированная (рис.1) классификация фактически рассматривает наивысший уровень формализации кибератак, который можно назвать общесценарным (рис.2). С него начинается процесс риск-анализа, характеризующего опасность рассматриваемых вторжений.

Чисто методически за ним следует уровень, на котором идентифицируются шаблоны атаки. Как правило это происходит с помощью ресурса CAPEC, и эти шаблоны задают каркас множественных кибератак (рис.1). CAPEC структурирует знания о методиках атак, что облегчает их анализ и прогнозирование. Его модель организует знания об атаках по следующим ключевым факторам:

- механизмы планирования и реализации атак;
- условия, которые необходимы для успешной атаки, потенциальный ущерб;
- методы обнаружения и предотвращения [10].

Дальнейшая детализация осуществляется при помощи MITRE ATT&K, где для всякого шаблона атаки может быть предложена последовательность реализующих её техник. MITRE ATT&K позволяет перейти от теоретического понимания угрозы к её практическому воплощению, учитывая:

-этапы развития атаки;

-особенности различных систем;

-методы закрепления в системы и обхода средств защиты;

- примеры применения [11-15].

Затем представляется возможным установить программные ошибки, которые могут использовать шаблоны и техники. Это осуществляется с помощью ресурса CWE. Перечень CWE обеспечивает наличие общего языка для описания недостатков программного обеспечения, стандартных единиц измерения инструментальных средств оценки защищенности, выявляющих эти уязвимости, основу для идентификации, уменьшения и предотвращения уязвимостей [17,87].

В свою очередь эксплуатируемые уязвимости можно определить из заданных ресурсов CVE и БДУ. CVE-идентификаторы обеспечивают основу баз данных уязвимостей инструментальных средств и сервисов, которые используются для оценки защищенности систем. В БДУ помимо основных угроз безопасности содержится список киберугроз, на основании сведений из БДУ специалисты могут выявлять и предотвращать утечки в процессе оптимизации информационных систем [16,18,87,88].

Вычисление вероятностей возможно с помощью данных ресурсов CVSS и EPSS, а величины ущерба с помощью CVSS и CISA KEV. [20,22,23-25].

Расчёт рисков компонентов и в целом атакуемой системы завершает процесс риск-анализа. На этом этапе определяются критические точки инфраструктуры, разрабатываются планы реагирования и меры для минимизации потенциального ущерба.

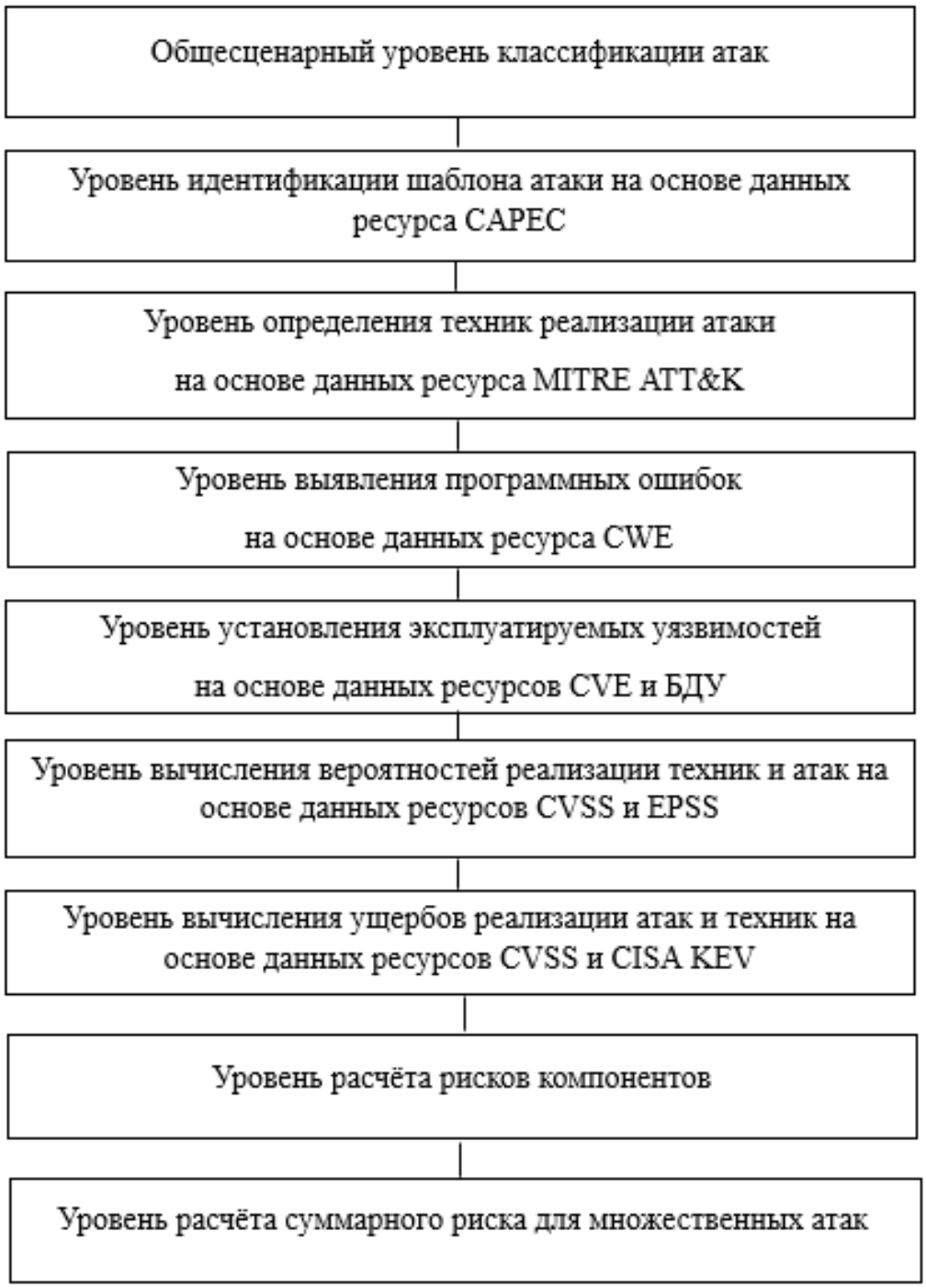


Рисунок 2 – Последовательность процедур риск-анализа кибератак

Рассмотренная последовательность процедур риск-анализа позволяет перейти к следующему разделу работы – детальному исследование интернет-ресурсов, которые содержат актуальные данные о кибератаках.

Для дальнейшего развития необходимо систематизировать и изучить специализированные онлайн-источники, которые постоянно обновляются,

появляются новые сведения о новых атаках, их методах и способах защиты. Такие базы данных как CAPEC, MITRE ATT&K, CWE, CVE, БДУ [10-18], представляют собой ценную базу для специалистов по защите информации.

1.2 Исследование интернет-ресурсов данных о кибератаках в контексте осуществления риск-моделирования

Современные подходы к оценке киберрисков требуют надежной информационной базы, объединяющей актуальные данные об уязвимостях, характеристиках атак и методах их эксплуатации. Особую значимость приобретают специализированные базы данных уязвимостей, такие как CAPEC, MITRA-ATT&CK, БДУ, CISA KEV, CWE, CVE [10-20]. Особое внимание уделяется возможностям и ограничениям существующих решений, а также перспективам их развития в контексте усложнения киберугроз и появления новых уязвимостей. Анализ информационного обеспечения позволяет определить оптимальный подход к сбору, обработке и использованию данных для построения эффективных моделей оценки киберрисков.

Основу методологии составляет специализированное информационное обеспечение, агрегирующее данные из источников. Система риск-моделирования предполагает комплексную работу с информацией: сбор, хранение и обработку сведений о киберугрозах, уязвимостях и тактиках злоумышленника. Базы данных CAPEC, MITRE ATT&CK, CISA KEV, CWE, CVE, БДУ ФСТЭК, NVD [10-21] обеспечивают доступ к структурированной информации, что значительно повышает точность оценки рисков.

CAPEC (Common Attack Pattern Enumeration and Classification) – это публично доступный каталог распространенных шаблонов кибератак, разрабатываемый и поддерживаемый организацией MITRE. Он представляет стандартизированное описание общих атрибутов и подходов, используемых злоумышленниками для эксплуатации уязвимостей в системах. Каждый шаблон систематизирует знания, о том, как разрабатываются и выполняются отдельные части атаки, а также дает

рекомендации по снижению эффективности атаки. Шаблоны помогают специалистам по защите информации лучше понять конкретные элементы атак и способы их предотвращения [10].

Специалисты по защите информации используют каталог CAPEC с целью:

- идентификации и анализа потенциальных атак, которые могут быть направлены на системы и приложения;

- разработки противодействующих мер в отношении атакующих методик и разработки стратегий, которые способны предотвратить их воздействие;

- планирования тестов на проникновение и оценки уязвимостей, для документирования атак [9,10].

Данные о вероятности успешности атак и о масштабе их потенциального ущерба, представленные в виде качественных оценок, доступны в информационной базе и предназначены для проведения риск-анализа.

В CAPEC используется иерархическая классификация, которая позволяет анализировать атаки с разной степенью глубины. Данная структура позволяет выявлять связи между различными типами атак и соответственно упрощает идентификацию методов, используемых злоумышленниками. Для каждого шаблона атаки предоставляется подробная информация, учитывающая контекст ее реализации.

Несмотря на обширный объем информации содержащийся в CAPEC, данная платформа не всегда обеспечивает понимание взаимосвязей между различными атаками, уязвимостями и техниками, которые использует злоумышленник. Существенным ограничением выступает отсутствие информации о мерах противодействия, что требует обращения к альтернативным источникам. Поэтому CAPEC, не смотря на свою полезность для специалистов, нельзя рассматривать как полноценную замену комплексной системе управления угрозами, включающая в себя не только сбор и анализ данных, но и разработку и внедрений стратегий по снижению риска [9,10].

Ресурс предоставляет исчерпывающую информацию об ошибках CWE, эксплуатирующиеся практически во всех шаблонах атак. Это подчеркивает важность CWE для формализации знаний о кибератаках. Так же некоторые шаблоны атак

CAPEC ссылаются на тактики и техники из MITRE ATT&CK. Поэтому целесообразным было бы проанализировать данный ресурс.

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) – это база знаний о тактиках и техниках кибератак, разработанная MITRE. Она используется для моделирования поведения злоумышленников, тестирования защиты и улучшения кибербезопасности [12-15].

Специалисты по безопасности могут сравнивать события моделями MITRE ATT&CK для лучшего понимания происходящего. Модели используются для проведения тестов на проникновение и моделирования реальных атак. Так же на основе MITRE ATT&CK есть возможность построения планов защиты, направленных на ославленные наиболее распространённых атак.

Актуальность использования данной базы знаний обусловлена постоянным обновлением базы данных, отражающим эволюцию тактик и техник атак. Так же поскольку она основана на реальных инцидентах, это делает её довольно-таки полезной для анализа актуальных угроз. MITRE ATT&CK позволяет анализировать тактики злоумышленника и прогнозировать их дальнейшее действия. MITRE ATT&CK легко взаимодействуют с другими ресурсами, такими как CAPEC, CWE, CVE, тем самым обеспечивая целостный подход к обеспечению кибербезопасности.

MITRE ATT&CK охватывает все этапы атаки, от разведки до воздействия на систему. База включает:

- тактики – цель злоумышленника на каждом этапе;
- техники – конкретные методы реализации атак;
- подтехники – более детализированные варианты исполнения;
- данные и реальных группах APT – сопоставление техник с конкретными хакерскими группировками. Взаимосвязь понятий изображена на рисунке 3 [12-15].

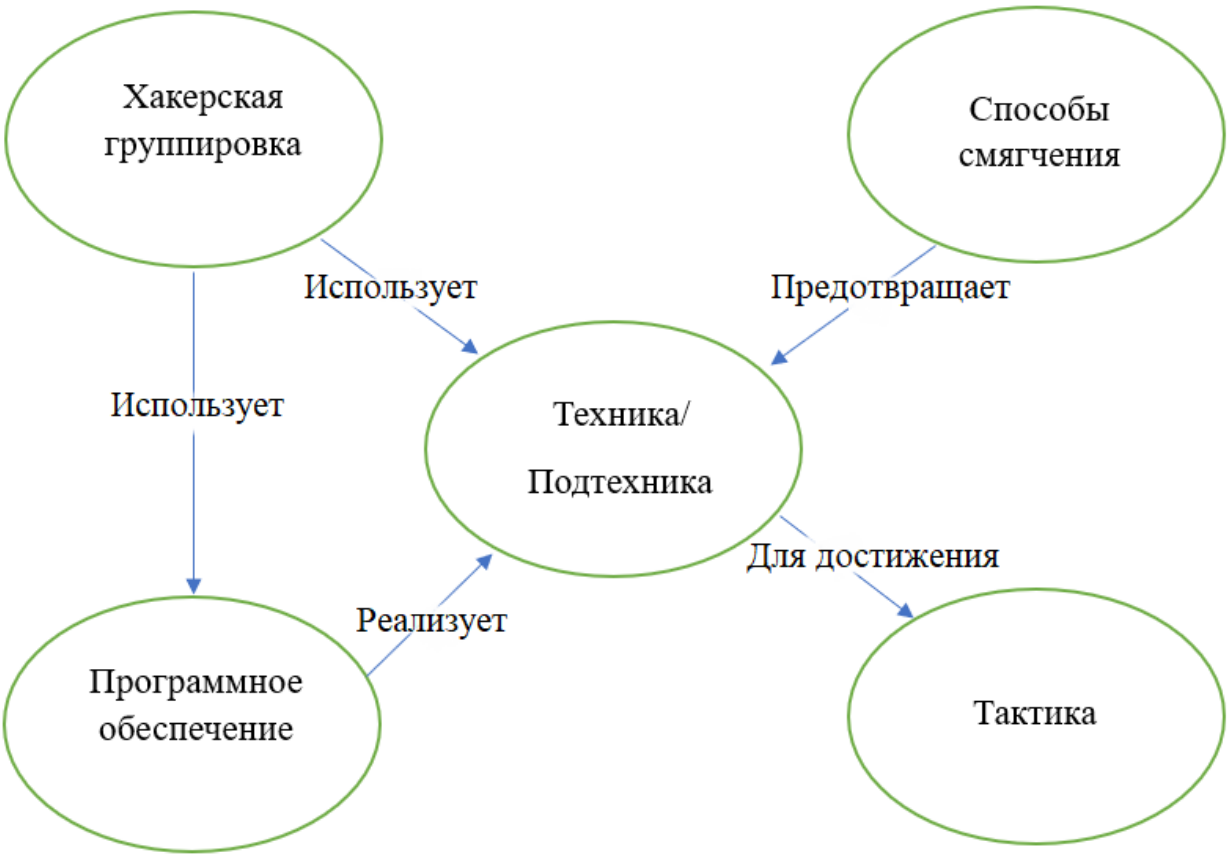


Рисунок 3 – Графическое представление взаимосвязи понятий MITRE ATT&CK

Применение MITRE ATT&CK в риск-анализе угроз. База данных является инструментом для сопоставления CVE с техниками ATT&CK, то есть позволяет проводить анализ на предмет того какие уязвимости могут быть использованы для конкретных атак. А также позволяет прогнозировать, если в системе есть уязвимость, то можно определить какие техники могут быть применены.

Как рассматривалось выше ресурс CAPEC непосредственно связан с базой CWE. Поэтому необходимо рассмотреть данный ресурс для дальнейшего исследования о кибератаках.

CWE (Common Weakness Enumeration) – это список распространённых слабых мест программного и аппаратного обеспечения. «Слабость» — это состояние в программном, встроенном программном обеспечении, аппаратном обеспечении или компоненте службы, способствующее появлению уязвимостей при определенных обстоятельствах [17]. Основная цель CWE – это предотвращение возникновения уязвимостей за счёт обучения специалистов способам исключения наиболее опасных

ошибок, что в итоге позволит избегать появления новых уязвимостей, которым подвержено программное обеспечение [9,17].

Ресурсом CWE активно пользуются, начиная от представителей производителей операционных систем и заканчивая исследовательскими институтами [9,17].

CWE предоставляет детальную информацию о различных слабостях, включая способы их эксплуатации, возможные методы исправления и последствия для системы, а также предоставляет примеры кода и примеры иллюстрирующие проблемы в продуктах. На данным момент база знаний охватывает 959 типов ошибок, что делает её ценным ресурсом для анализа и устранения программных ошибок [17].

Целями являются:

- классификация (стандартизация терминов и понятий, связанных с ошибками и уязвимостями);

- анализ рисков (возможность проводить оценку уровня рисков, связанного с определёнными видами ошибок);

- улучшение качества ПО (обеспечение разработчиков рекомендациями по предотвращению появления известных уязвимостей).

Описание слабости строго структурирована и содержит в себе следующую информацию:

- CWE- ID;

- описание;

- вероятность эксплуатации;

- общие подробности;

- способы предотвращения;

- примеры;

- ссылки на актуальные CWE;

- информация о связях с другими элементами;

- источники.

Пример описания слабости представлен в таблице 1.

Таблица 1 – Пример описания слабости

CWE- ID	Уникальный номер, присвоенный каждой слабости
Описание	Подробная информация о природе уязвимости
Вероятность эксплуатации	Показатель, отражающий степень возможности успешного использования злоумышленником выявленной слабости
Общие подробности	Технические подробности реализации слабости, такие как языки программирования, платформы, инструменты разработки
Способы предотвращения	Рекомендации по снижению последствий
Примеры	Примеры случаев проявления данной слабости в коде или в системе
Ссылки на актуальные CWE	Список связных слабостей, показывающих цепочку проблем
Информация о связях с другими элементами	Соответствующие шаблоны атак, относящиеся к слабости
Источники	Внешние ресурсы, подтверждающие существование и значимость конкретной уязвимости

Не смотря на обширность данных, база CWE не является практичным инструментом для анализа рисков. Ее основное назначение обучать специалистов предотвращать типичные программные ошибки.

CWE позволяет сопоставлять информацию о уязвимостях с другими источниками, такими как NVD NIST [21], а также очевидной взаимосвязью шаблонов атаки CAPEC [10] и типов ошибок CWE [17], будет являться взаимосвязь – уязвимостям CVE [9].

CVE (Common Vulnerabilities and Exposures) – это общедоступный каталог известных уязвимостей и ошибок в программном, аппаратном обеспечениях и прочих системах. Данная база данных помогает координировать устранение уязвимостей, позволяет автоматизировать проверки безопасности (например, через сканеры

уязвимостей), а также дает пользователям информацию о рисках и обновлениях [16].

По данным на март 2025 года в базе CVE (Common Vulnerabilities and Exposures) содержатся более 270 тысяч записей об известных уязвимостях. За первый квартал 2025 года в киберпространстве были зафиксированы атаки, которые используют 159 уникальных уязвимостей с присвоенными CVE-идентификаторами. База данных CVE, имеет некоторые ограничения не выполняет функции комплексной базы данных об уязвимостях, ограничиваюсь их систематизированным перечислением посредство уникальных идентификаторов. Это обусловлено тем, что формат предоставления информации минималистичен: записи CVE содержат лишь базовые описания уязвимостей и ссылки на внешние ресурсы, что существенно снижает практическую применимость системы для оперативного анализа угроз. Поэтому на основе CVE и существует множество баз, дополняющих её, использующие CVE в качестве основы, дополнят её структурированными метаданными, оценками критичности (CVSS), эксплойтами и рекомендациями по устранению уязвимостей [89].

Использование базы знаний CVE важно для обеспечения информационной безопасности, так как она содержит стандартизированную информацию об уязвимостях, что позволяет их отслеживать и устранять [9,16,89].

База CVE служит репозиторием информации об уязвимостях в программном обеспечении, включая в себя описание, уникальный идентификатор и ссылки на ресурсы с дополнительными сведениями. В настоящее время в базе содержится более 200 тысяч записей об уязвимостях. Производители регулярно выпускают патчи и обновлениями, соответственно уязвимости устранение посредством обновлений больше не подлежат эксплуатации [9,16].

CVE тесно связана с другими ресурсами, такими как NVD, предоставляющая дополнительную информацию для каждой уязвимости. Эта интеграция обогащает CVE, тем самым делая её полезной для анализа угроз и управления рисками. Соответственно можно отследить смысловую последовательность «шаблон атаки CAPEC – ошибки программного обеспечения CWE – уязвимость CVE» [9].

Представляется возможным рассмотреть отечественную базу данных БДУ ФСТЭК, поскольку они тесно связаны с CVE, потому что БДУ является системой,

использующей идентификаторы CVE для классификации и отслеживания уязвимостей.

НКЦКИ (Национальный координационный центр по компьютерным инцидентам) обеспечивает координацию деятельности субъектов Российской Федерации по вопросам обнаружения, предупреждения и ликвидации последствий компьютерных атак и реагирования на компьютерные инциденты [19,79].

В базе знаний представлены уязвимости, которые были зарегистрированы при реальных инцидентах на инфраструктуру субъекта РФ и представляют наибольшую угрозу безопасности информации. База знаний обновляется несколько раз в неделю.

Основываясь на данных, представленных в базе знаний будем выявлять такие уязвимости, успешная эксплуатация которых подтверждена реальными инцидентами, то есть уязвимость, имеющееся в паре с вектором атаки является успешной реализаций сценария атаки. Исходя из этого утверждения становится возможным модернизация методического обеспечения оценки рисков, включающая в себя такие показатели как успешность реализации сценария и критичность [19,79].

База НКЦКИ включает в себя идентификатор уязвимости CVE, описание уязвимости, категорию уязвимого продукта, уровень опасности по CVSS, возможные последствия, метод эксплуатации, а также идентификатор программной ошибки CWE. Всего в базе НКЦКИ на сегодняшний день насчитывается 7666 уязвимостей [19,79].

БДУ ФСТЭК (Банк данных угроз безопасности ФСТЭК России) – это база данных, содержащая сведения об уязвимостях программного и программно-аппаратного обеспечения, а также перечень и описание угроз безопасности информации для информационных систем различного назначения. На сегодняшний день в базе данных 222 записи угроз и 57564 записей уязвимостей, актуальных для государственных информационных систем, информационных систем персональных данных и автоматизированных систем управления технологическими процессами на объектах критической информационной инфраструктуры. База данных помимо названия и кода угрозы, содержит ее краткое описание, вероятные источники, объекты воздействия и последствия, которые влекут за собой реализации угроз [18].

Целью создания БДУ ФСТЭК России является предоставление информационной и методической поддержки государственным органам и организациям в деятельности по определению, оценке и моделированию угроз безопасности информации, а также в выявлении, анализе, и устранении уязвимостей в автоматизированных информационных системах, а также в программном обеспечении и средствах защиты информации. База используется также для подтверждения соответствия таких систем и средств обязательным требованиям и поддержания программных средств контроля защищенности информации [18,79].

БДУ ФСТЭК взаимосвязана с различными ресурсами производителей программного обеспечения, которые публикуют уязвимости своих продуктов, а также взаимосвязана с другими базами уязвимостей, такими как NVD, CERT, а также с другими частными исследователями уязвимостей. Такая взаимосвязь существенно расширяет возможности БДУ ФСТЭК, что дает возможность точно сопоставить шаблон атаки CAPEC с соответствующими ему уязвимостями [18,79].

На сегодняшний день БДУ популярен, поскольку учитывает специфику российского ИТ-ландшафта (импортозамещение, отечественное ПО), отражает активность APT-групп, ориентированных на РФ.

Как рассматривалось выше CVE тесно связана NVD.

NVD (National Vulnerability Database) – это репозиторий уязвимостей, поддерживаемый NIST, предоставляет стандартизированную информацию об известных уязвимостях программного, аппаратного обеспечениях, а также веб-приложениях. Эта информация позволяет автоматизировать управление уязвимостями, измерения безопасности и обеспечение соответствия требованиям.NVD включает в себя базы данных ссылок на контрольные списки безопасности, программные недостатки, названия продуктов и метрики воздействиях [21].

NVD – обогащает CVE, опубликованные в списке CVE, путем агрегирования точек данных из описания, предоставленных ссылок и других дополнительных данных, находящихся в открытом доступе на моменте публикации. Это обогащение приводит к объединению метрик воздействия CVSS и типов уязвимостей CWE и

утверждений о применении, а также других методанных. Оценки CVSS и CWE могут изменяться, по мере обновления дополнительной информации. Каждая уязвимость, которая занесена в NVD, имеет свой уникальный идентификатор CVE, позволяющий ссылаться на эту уязвимость [21]. Так количество уязвимостей с каждым годом пополняется это можно заметить на диаграмме рисунок 4.

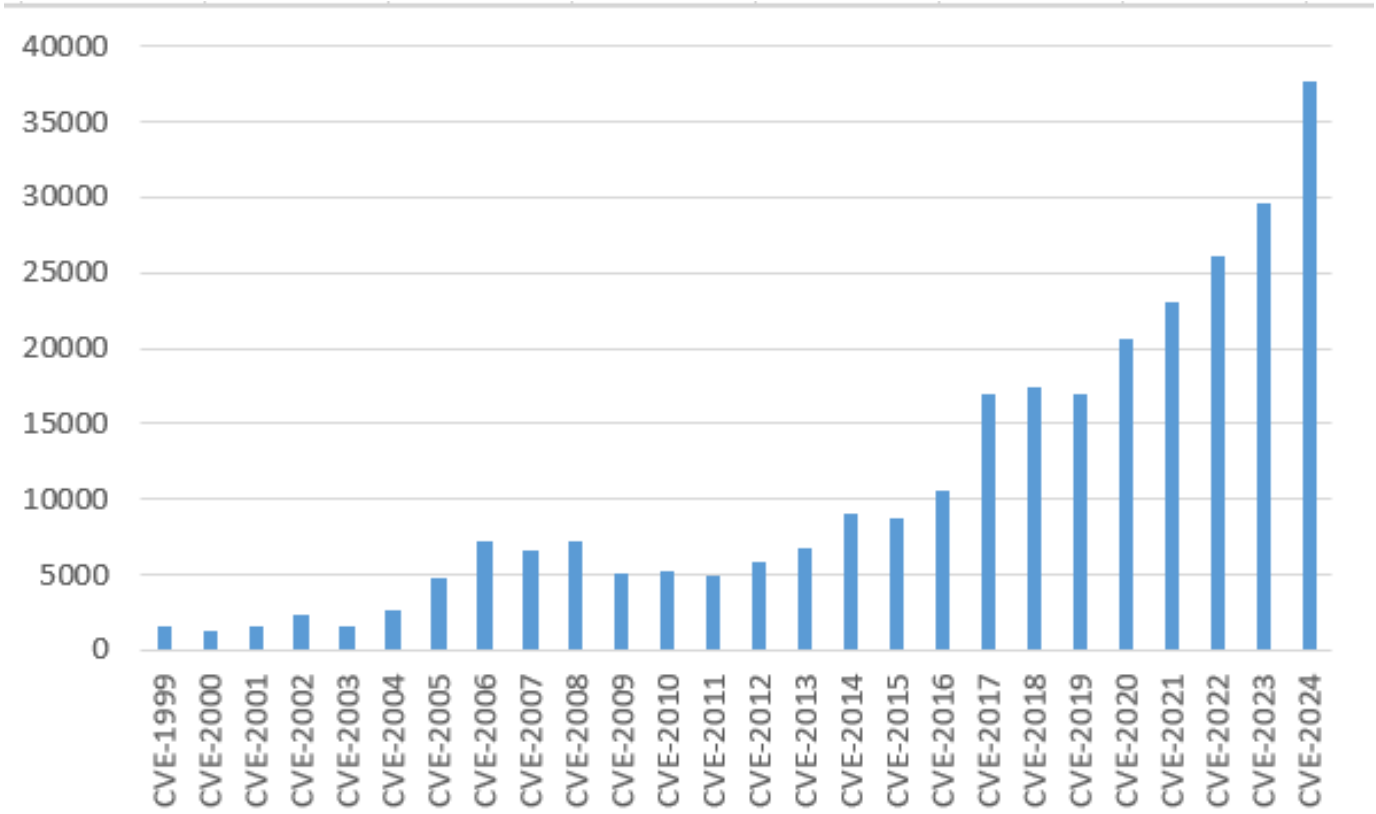


Рисунок 4 – Прирост количества уязвимостей в базе данных NVD

NVD представляет векторную строку CVSS, позволяющая анализировать метрики, которые влияют на оценку.

NVD – значимая база данных, так как представляет стандартизированную информацию об уязвимостях, необходимая для управления уязвимостями, анализа рисков, разработки патчей и создания средств защиты [21].

Обратимся к следующему ресурсу, который непосредственно основан на использовании базы знаний CVE [9].

CISA KEV – это каталог известных эксплуатируемых уязвимостей, который ведется агентством по кибербезопасности и защите инфраструктуры. Каталог

представляет собой справочник уязвимостей, активно использующиеся хакерами по всему миру. Цель каталога предоставить информацию об уязвимостях, для принятия мер для защиты от атак [20]. Для обновления каталога KEV, необходимы следующие критерии, лежащие в основе каждого из трех пороговых значений:

- уязвимости присвоен идентификатор CVE (Common Vulnerabilities and Exposures);

- существуют достоверные данные о том, что уязвимость активно эксплуатировалась;

- существует четкое действие по устранению уязвимости, например обновление, предоставленное поставщиком [20].

Количество уязвимостей в каталоге KEV меняется еженедельно. По данным на начало 2025 года, в нем насчитывается более 1000 записей, охватывая широкий спектр технологий и сервисов, начиная от операционных систем и заканчивая специализированными приложениями [20].

В базе данных CISA KEV собрана сведения об уязвимостях, которые использовались злоумышленники в реальных киберинцидентах. База данных постоянно обновляется, отражая последние тенденции в мире киберугроз, и помогает специалистам по защите информации. Особенно важную роль CISA KEV играет в обеспечении безопасности государственных информационных систем, поскольку устранение уязвимостей, которые перечислены в CISA KEV является обязательным требованием, установленным Директивой по оперативным действиям (BOD) 22-01[9].

Информация, описывающая уязвимости информационного ресурса CISA KEV, сравнима по аналогии с CVE NIST. А также она включает описание метрик для подсчета оценки критичности CVSS [9,48]

Современные угрозы кибербезопасности риска становятся все более сложными и разнообразными. Поэтому необходимы точные и объективные методы оценки риска, обеспечивающие глубокое понимание возможных угроз и последствий их реализации. Калькуляторы предоставляют методики оценки уязвимостей, сочетая количественные и качественные показатели. Их применение позволяет сформировать

точную градацию рисков, и выявить наиболее значимые уязвимости и предсказать вероятные сценарии их эксплуатации, полагаясь на общепринятые шкалы измерения, калькуляторы гарантируют объективный подход к определению уровня уязвимостей.

1.3 Установление взаимосвязей между базами данных для описания процессов реализации кибератак

В основе алгоритма автоматического поиска соответствий между базами данных, лежит методика, которая способна анализировать базы данных и извлекать информацию, которая необходима для оценки рисков и выработке защитных мер. Используя нейросетевые возможности обработки, тем самым можно минимизировать использованное время на ручного анализ данных. Графическое представление взаимосвязи баз данных приведено на рисунке 5.

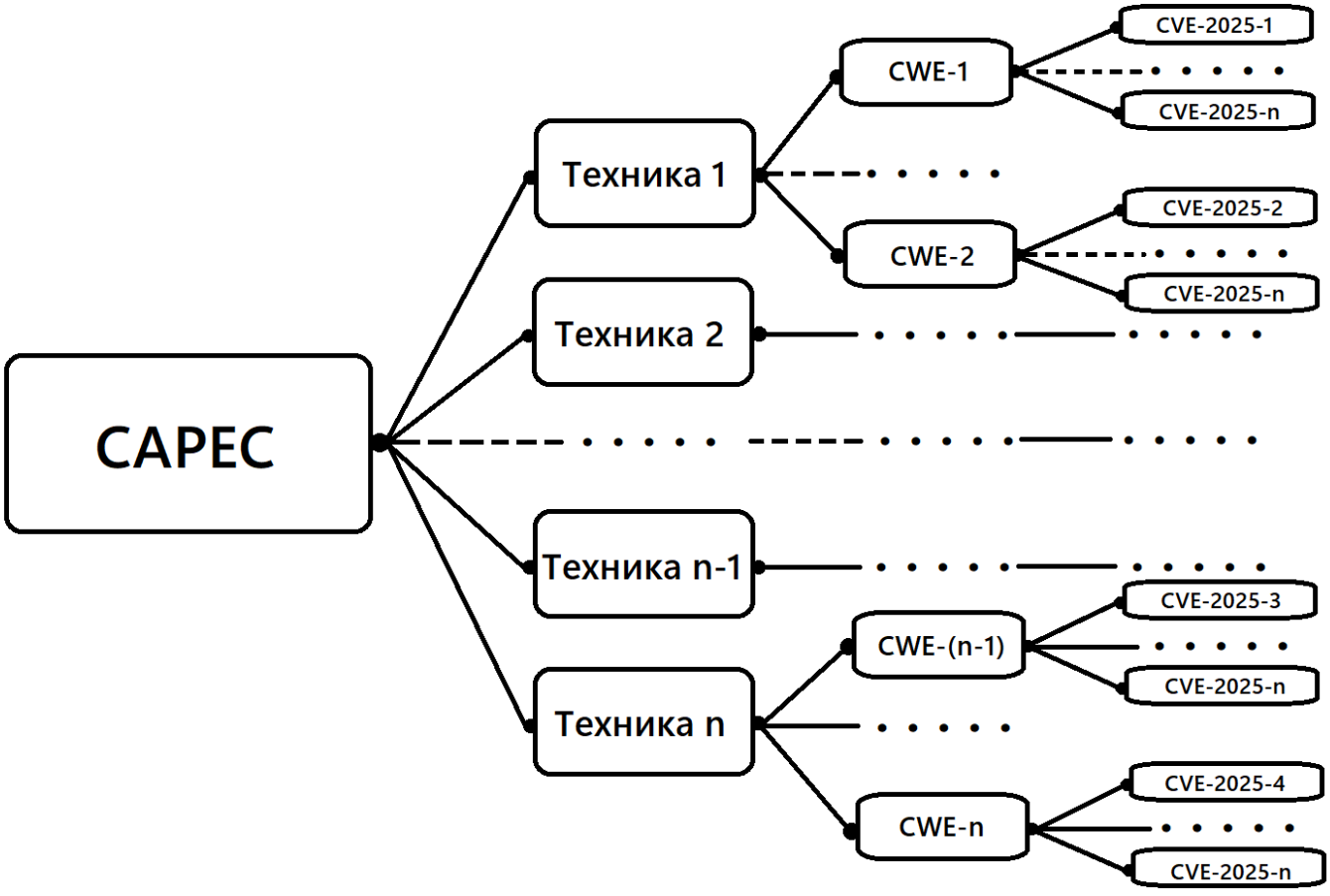


Рисунок 5– Связь между базами данных

Процесс сопоставления угроз начинается с использования базы знаний CAPEC [10], классифицирующая методы атак, затем используется MITRE ATT&CK [11-15], которая содержит в себе информацию и тактиках и техниках злоумышленников. Каждая техника идентифицируется кодом и подробным описанием, примерами и информацией о связанных уязвимостях.

После того как осуществлена связь техник со способами их реализации, далее происходит сопоставление с базой CWE, она предоставляет информацию и уникальных идентификаторах и описания, с помощью чего можно сделать вывод о том какие именно уязвимости могут быть эксплуатированы в рамках рассматриваемой техники.

Далее, после базы CWE, используется база CVE для выявления конкретных уязвимостей в программном обеспечении. База данных позволяет узнать информацию о каждой уязвимости, ее идентификаторе и список уязвимого ПО.

Таким образом стоится связь CAPEC→техники MITRE ATT&CK→CWE→CVE. На основе построенных связей и рассчитываются всевозможные варианты сценариев и показатели риска для рассматриваемых типов атак. В графическом представлении шаблон техник будет выглядеть следующим образом (рисунок 6)

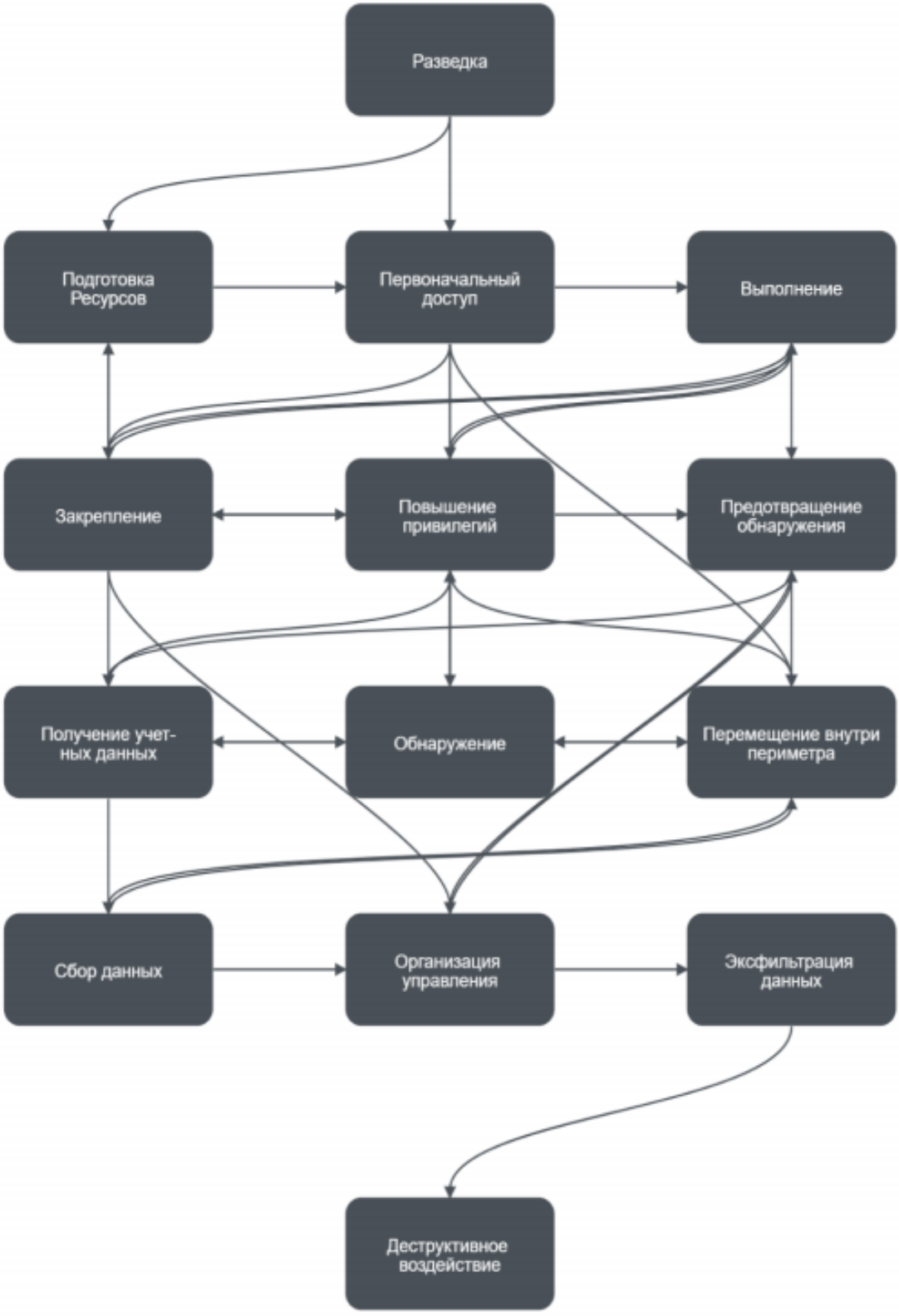


Рисунок 6 – Графическое представление шаблона атак

На основе этого шаблона генерируются различные сценарии, и впоследствии рассчитываются.

1.4 Средства калькуляции рисков кибератак

Предлагаемый подход к обеспечению основан на понимании безопасности системы через призму риска, который является количественной оценкой возможности нанесения ущерба. Риск, в свою очередь, определятся как произведение потенциального ущерба на вероятность его возникновения. Эта формула подчеркивает прямую зависимость между величиной ущерба и вероятностью его наступления. И целесообразно оценивать опасность возникающих вредоносных пар вектор атаки – уязвимость [42,44,48].

Как упомянуто в разделе выше в ресурсе CISA KEV [20] включено описание метрик для подсчета оценки критичности CVSS [20,23-25].

Тогда представляется необходимым проанализировать особенности калькулятора риска CVSS [23-25].

CVSS (Common Vulnerability Scoring System) - это система, которая позволяет осуществлять сравнение уязвимостей программного обеспечения с точки зрения их опасности [23-25]. Информационный ресурс NVD NIST приводит количественные показатели метрик, использующиеся для подсчета оценки критичности. Существуют несколько версий калькулятора.

1. CVSS 2.0. Система CVSS 2.0 оценивает уязвимости по трем ключевым метрикам: базовой, временной и контекстной. Группа базовых метрик отражает аспекты опасности уязвимости, влияющие на доступность, целостность и конфиденциальность информации. Группа временных метрик отражает характеристики уязвимости, которые изменяются со временем (подтверждение технических параметров уязвимости, статус исправления уязвимости и доступность технологии эксплуатации), но не зависят от среды функционирования программного обеспечения. Группа контекстных метрик отражает характеристики уязвимости, зависящие от среды функционирования программного обеспечения. Каждая метрика представляет из себя оценку от 0 до 10 баллов и короткое текстовое описание, содержащее всю необходимую информацию для вывода этой оценки [23]. Система оценки уязвимостей в общем виде отражена на рисунке 7.

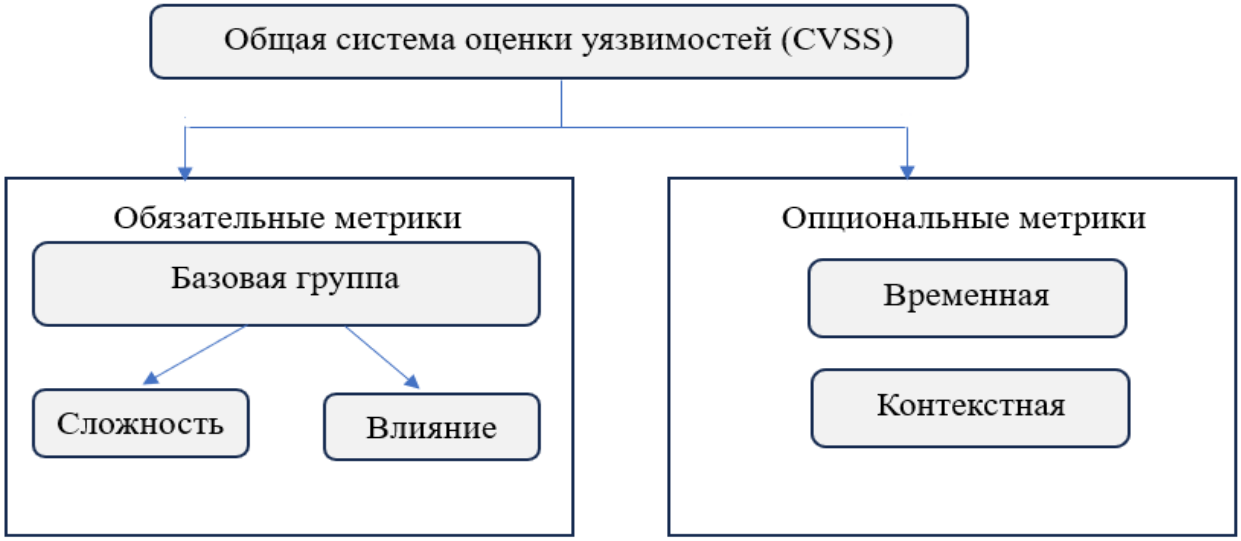


Рисунок 7 – Общая система оценки уязвимостей CVSS 2.0

Оценка состоит из следующих базовых метрик:

- вектор доступа (Access Vector) (AV) – показывает каким путем уязвимость может быть внедрена. Значения: локальный(L) – 0,5; соседняя сеть (A) – 0,7; сетевой (N) – 0,9.

- сложность доступа (Access Complexity) (AC) – показывает, насколько легко или сложно использовать уязвимость. Значения: high (высокая сложность) – 0,5; medium (средняя сложность) – 0,7; low (низкая сложность) – 0,9.

- аутентификационный параметр (AU), параметр оценивает количество аутентификаций, которые атакующий должен произвести прежде, чем воспользоваться уязвимостью. Значения: множественный(M) – 0,5; одиночный(S) – 0,7; отсутствует(N) – 0,9 [23].

Недостатки: слишком упрощенная модель, например Access Complexity, не учитывает современные атаки, так как этот компонент описывает сложность эксплуатации уязвимости удаленным атакующим. Так же модель CVSS 2.0. не имеет четкого разделения на локальные и сетевые атаки, хотя такие различия критически важны.

Информацию об уязвимостях следует воспринимать с осторожностью,

поскольку она базируется на экспертных оценках, которые содержать элемент субъективности. К тому же производители не всегда раскрывают информацию об уязвимостях своих продуктов.

Метрики должны быть адаптированы к конкретным требованиям безопасности системы, в которой используется продукт.

Ущерб, который может быть нанесён уязвимостью, зависит от конкретной защищаемой системы. Но, к сожалению, формализация процесса выявления и оценки необходимых параметров для расчета ущерба является сложной задачей, что существенно затрудняет практическую калькуляцию, особенно при большом количестве уязвимостей.

Рассматривая аналитические выражения расчетов для второй версии CVSS, то они будут выглядеть следующем образом:

$$E= 20 * AV * AC* Au;$$

$$Влияние = 10,41[1- (1-C) (1-I) (1-A)]$$

Тогда, можно сказать, что, форма, взятая их теории вероятности

$$1 - (1 - \mathrm{C})(1 - I)(1 - A) = C + I + A - CI - IA - CA + CIA$$

Порождает знакопеременный ряд, который включает в себя отдельные, парные и тройные комбинации нарушения конфиденциальности, целостности и доступности. Это создает трудности для риск-анализа, поскольку необходимо приводить все разнородные комбинации к единой шкале оценки ущерба.

Также нужно приводить обоснование, почему для расчета этих метрик перемножаются параметры. И похоже, что конкретные числа, используемые в расчетах, получены эмпирическим путем, методом проб и ошибок. Однако, гарантии что эти значения будут верны и применимы в любой ситуации нет [9,42,44,48].

2. CVSS 3.1. Так как предыдущая версия CVSS имеет существенные недостатки, рабочая группа CVSS разработала следующей версию стандарта [24]. Система оценки уязвимостей в общем виде отражена на рисунке 8.

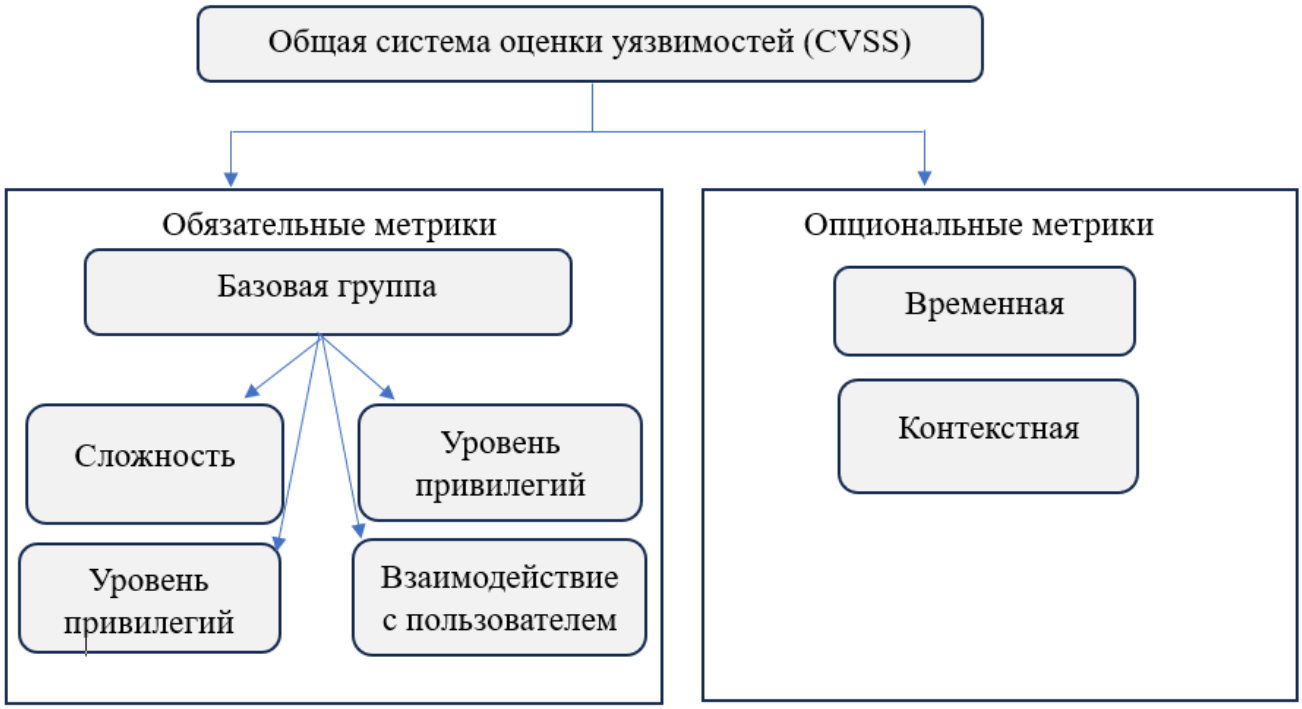


Рисунок 8 –Общая система оценки уязвимостей CVSS 3.1

Оценка состоит из следующих базовых метрик:

- вектор атаки (Attack Vector) (AV) – степень удаленности потенциального атакующего от уязвимого объекта. Значения: локальный(L) – 0,5; соседняя сеть(A) – 0,7; сетевой(N) – 0,9; физический(P) – 0,3.

- сложность эксплуатации уязвимости (Attack Complexity) (AC) – количественная оценка сложности проведения атаки. Значения high (высокая сложность) – 0,3; low (низкая сложность) – 0,8.

- требуемый уровень привилегий (Privileges Required) (PR) – показывает требуется ли аутентификация для проведения атаки, и если требуется, то какая именно. Значения: high (высокий уровень привилегий) – 0,3; low (низкий уровень привилегий) – 0,5; none (не требуется) – 0,8.

- необходимость взаимодействия с пользователем (User Interaction) (UI). Значения: требуется – 0,3; не требуется – 0,8 [24].

Временные метрики оценивают текущее состояние уязвимости и ее влияние на период жизни уязвимости. Эти метрики предназначены для мониторинга

меняющихся факторов, таких как зрелость эксплойта и доступность патчей. Они представляют собой:

1. Эксплуатационная зрелость (Exploit Code Maturity) (ECM) – это показатель уровня развития и доступности рабочего эксплойта для уязвимости.

2. Уровень устранения (Remediation Level) (RL) – это показатель наличия официального исправления или способа смягчения уязвимости.

3. Достоверность информации (Report Confidence) (RC) – показатель уверенности в достоверности о данной уязвимости.

Контекстные метрики учитывают уникальные характеристики среды, в которой находится уязвимая система, позволяющие адаптировать базовую оценку риска под конкретные условия эксплуатации. Они включают в себя:

1. Конфиденциальность (Confidentiality Requirement) (CR) – уровень требований к конфиденциальности данных, которые хранятся в системе.

2. Целостность (Integrity Requirement) (IR) – уровень требований к сохранению целостности данных и программных компонентов.

3. Доступность (Availability Requirement) (AR) – уровень доступности функций системы.

Недостатки: модель CVSS 3.1 иногда модель может завышать оценки для сложных атак, тем самым заставляет специалиста тратить больше ресурсов на низкоприоритетные задачи, отвлекаясь от реальных угроз [24].

3. CVSS 4.0. В версии 4.0 системы оценки уязвимостей были добавлены новые метрики, связанные с облачными технологиями, мобильными устройствами и Интернетом вещей (IoT) [25]. Оценка уязвимостей CVSS 4.0 изображена в общем виде на рисунке 9.

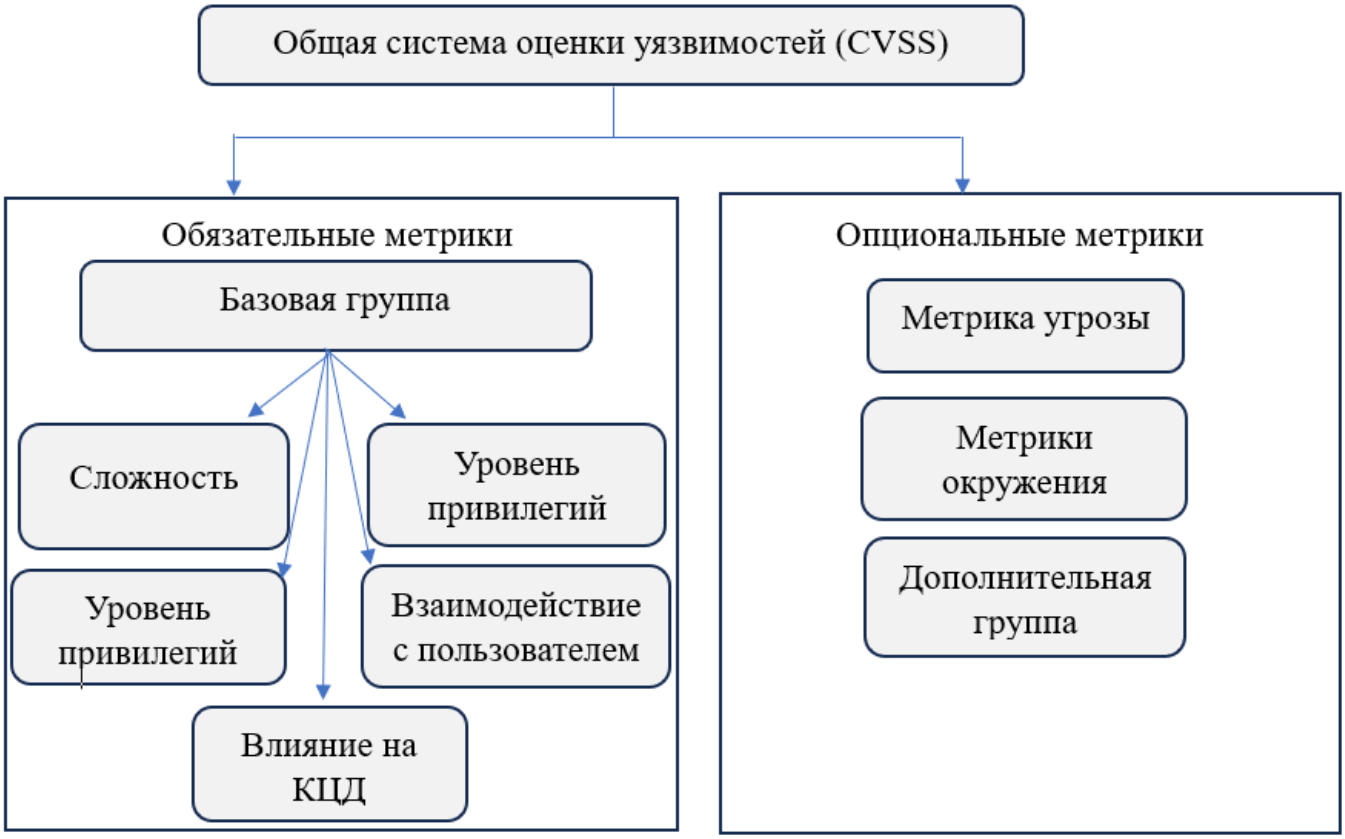


Рисунок 9 – Общая система оценки уязвимостей CVSS 4.0

Оценка состоит из следующих базовых метрик:

- вектор атаки (Attack Vector) (AV). Значения: локальный(L) – 0,5; соседняя сеть(A) – 0,7; сетевой(N) – 0,9; физический(P) – 0,3.

- сложность атаки (AC). Значения high (высокая сложность) – 0,3; low (низкая сложность) – 0,8.

- требуемые привилегии (AT). high (высокий уровень привилегий) – 0,3; low (низкий уровень привилегий) – 0,5; none (не требуется) – 0,8.

- необходимость взаимодействия с пользователем (User Interaction) (UI). Значения: не требуется(N); пассивное(P); активное (A).

- влияние на конфиденциальность целостность и доступность (VC, VI, VA).

Метрика угрозы, ранее в CVSS 3.1 «Временные метрики», были сокращены до одной субметрики. Данный показатель «Доступность средств эксплуатации (E)» показывает, существует ли эксплойт и как доступный код связан с уязвимостью. Эти факторы будут повышать или понижать оценку независимо от пользовательских

конфигураций.

Метрики окружения показывают уникальные характеристики уязвимости к конкретной среде организации [25].

Дополнительные метрики добавляют детали к уязвимостям, позволяя определять приоритеты, которые определяет пользователь. Они включают:

- влияние на безопасность (S), значения: существенно (P), незначительно(N), не определенно (X);

- автоматизация эксплуатации (AU), значения: возможна (Y), невозможна(N), не определена(X);

- восстановление работоспособности(R), значения: автоматически (A), вручную (U), невозможно(I), не определена(X);

- ресурсы, получаемые с помощью одного события эксплуатации(V), значения: ограниченные (D), множественные(C), не определены(X);

- условия по реагированию на уязвимость (RE), значения: минимальные(L), умеренные(M), значительные(H), не определены(X);

- срочность исправления(U), значения: низкая(clear), средняя(green), высокая (amber), критическая (red), не определена (X) [25];

Недостатки: пока менее распространен, чем CVSS 3.1 и требует больше данных для расчёта.

Если необходимо провести оценку, то лучше ориентироваться на версию 3.1, поскольку версия 4.0 хоть и перспективная, но её внедрение ещё в процессе.

Рассматривая вычисление вероятностей реализации техник и атак, помимо CVSS, представляется возможным проанализировать особенности калькулятора EPSS и сравнить его с CVSS.

EPSS (Exploit Prediction Scoring System) представляет новый подход к оценке уязвимостей, отличающийся от большинства систем. Вместо перехода от причины к оценке, EPSS использует обратный метод, основываясь на фактических результатах. В отличие от CVSS, EPSS не включает номинальные компоненты, а его эффективность обусловлена качеством данных[22, 42,44,48].

EPSS основывается на статистических моделях, которые используют данные об

уязвимостях, связанных с ними событиях и факторах риска. Основное внимание уделяется байесовским моделям вероятности, анализа взаимосвязей между уязвимостями и данными о нападениях. Принцип работы включает в себя следующее:

1. Сбор данных: EPSS анализирует множество параметров уязвимостей, таких как тип уязвимости, связанные CVE (Common Vulnerabilities and Exposures) коды, а также внешние данные – отчёты о случаях эксплуатации и активности угроз.

2. Обработка факторов риска: система использует факторы, связанные с эксплойтами, такие как наличие уязвимостей в открытых источниках, информация о патчах, и данные об активности злоумышленников. Важными метриками также являются сложность эксплуатации и степень потенциального ущерба.

3. Моделирование и предсказание: EPSS оценивает вероятность того, что уязвимость будет использована в течение определённого времени (как правило, 30 дней), и выдаёт оценку на основе вероятностных моделей. В EPSS шкала измерения колеблется от 0 до 1.

Пять основных факторов, влияющих на результаты EPSS таковы:

1) уязвимый код,

2) запись в базе данных Exploit,

3) количество ссылок в Национальной базе данных уязвимостей,

4) поставщик – есть ли Microsoft среди них,

5) наличие эксплойта в Metasploit.

Важно отметить, что EPSS не предлагает четкой причинно-следственной модели. Например, указание на Microsoft может означать популярность ПО, медленное обновление клиентами или слабую безопасность [[22, 42,44,48]].

Произвольные границы в оценке могут привести к различиям в обработке схожих уязвимостей. Например, при пороге 0,5 уязвимости с вероятностями 0,499 и 0,501 будут оцениваться одинаково, что может привести к потере информации.

Многие организации используют EPSS в сочетании с системой CVSS (Common Vulnerability Scoring System) для лучшей оценки уязвимостей и принятия решений о внедрении патчей или других защитных мер.

Несмотря на полезность EPSS, у системы есть и недостатки:

1. Ограниченность данных: EPSS полагается на доступные данные об уязвимостях и случаях их эксплуатации, что может ограничивать её точность для менее известных уязвимостей.

2. Не учёт особенностей инфраструктуры: EPSS не принимает во внимание уникальные черты IT-инфраструктуры отдельной организации, включая специфические сетевые конфигурации, что может привести к снижению точности оценки в контексте конкретных условий.

3. Вероятностный подход: модель EPSS оценивает только вероятность эксплуатации, а не её потенциальные последствия [22, 42,44,48].

Ввиду вышеописанного, можно сделать следующий вывод, средства калькуляции CVSS и EPSS являются взаимодополняющими друг друга, поскольку помогают эффективно управлять уязвимостями и снижать киберугрозы. CVSS, оценивая технические характеристики уязвимости, позволяет понять насколько серьёзными могут быть последствия ее эксплуатации. EPSS, в свою очередь, анализирует текущую ситуацию с эксплойтами, помогает определить какие уязвимости будут использованы злоумышленниками с наибольшей вероятность. Совместное использование CVSS и EPSS позволяет не просто реагировать на уязвимости, но и активно предвидеть и предотвращать потенциальные атаки, оптимизируя использование ресурсов.

OWASP Risk Assessment Calculator – представляет собой специализированный инструмент, разработанный организацией OWASP для оценки рисков уязвимостей веб-приложений [26, 42,44,48]. Этот калькулятор выполняет 2 ключевые функции:

1. Оценка степени риска – анализирует как технические параметры уязвимости, так и ее потенциальное влияние на бизнес-аспекты угрозы.

2. Определение критичности уязвимости – классифицирует уязвимости по уровню опасности.

Основная задача инструмента – стандартизация процесса оценки рисков, что позволяет специалистам по безопасности выстраивать приоритеты устранения уязвимостей и принимать обоснованные решения на основе единой методологии.

Данный инструмент построен на методологии управления рискам и

анализирует следующие ключевые составляющие: вероятность эксплуатации уязвимости и потенциальный ущерб в случае успешной атаки. Каждая из этих категорий разделены на метрики, каждая из которых оценивается по шкале от низкого до высокого. После оценки каждой из метрик калькулятор проводит итоговую оценку уровня риска. Так же калькулятор часто используют в связке с OWASP Top 10 для идентификации наиболее критичных категорий уязвимостей и OWASP ASVS (Application Security Verification Standard) для приоритизации исправления уязвимостей [26, 42,44,48].

OWASP Risk Rating Calculator включает в себя следующие метрики:

1.Параметры злоумышленника:

-уровень квалификации: отсутствие технических навыков (1); наличие некоторых технических навыков (3); продвинутый пользователь ПК (5); навыки сетевого администрирования и программирования (6); навыки взлома систем безопасности (9);

- мотив: низкое вознаграждение или его отсутствие (1); потенциальное награждение (4); высокая награда (9);

-возможности: необходим полный доступ или дорогие ресурсы (0); требуется специальный доступ или ресурсы (4); необходим некоторый доступ или ресурсы (7); доступ или ресурсы не требуются (9);

- размер: разработчики и системные администраторы (2); пользователи интернета (4); партнеры (5); аутентифицированные пользователи (6); анонимные интернет-пользователи (9).

2. Параметры уязвимости:

- простота обнаружения: практически невозможно (1); сложно (3); легко (7); имеются автоматизированные инструменты (9);

- простота эксплуатации: теоретический (1); сложно (3); легко (5); имеются автоматизированные инструменты (9);

- осведомленность: неизвестный (1); скрытый (4); очевидное (6); информация в публичном доступе (9);

- обнаружение вторжений: активное обнаружение в применении (1);

зарегистрировано и просмотрено (3); зарегистрировано без проверки (8); не зарегистрировано (9).

3. Технические факторы воздействия:

- потеря конфиденциальности: раскрытие максимального количества нечувствительных данных (2);

- раскрытие максимально важных данных (6);

- раскрытие обширных неконфеденциальных данных (6);

- раскрытие обширных критических данных (7);

- все данные раскрыты (9).

Хотя OWASP Risk Assessment Calculator при его достоинствах таких как стандартизированная методика оценки рисков, учет бизнес-контекста, удобство применения и совместимость с другими инструментами, имеет и существенные недостатки:

1.Упрощенная агрегация параметров, OWASP Risk Assessment Calculator не позволяет адаптировать критерии оценки под индивидуальные нужды организации с более сложными требованиями по безопасности.

2. Не учитывает современные угрозы, так как инструмент обновляется редко, он может не учитывать некоторые современные векторы атак и специфические типы угроз.

3. Использование субъективных критериев при оценке рисков способно вызывать различие в результатах. Определение метрик зачастую определяется опытом экспертов в области безопасности, что может привести к появлению разных оценок одной и той же уязвимости разными специалистами [26, 42,44,48].

OWASP Risk Assessment Calculator является эффективным решением для оценки рисков, на основе технических и бизнес-аспектов. Его достоинства будет идеальны лишь для средних и малых предприятий, потому что для крупных организаций калькулятор может предоставить не полную детализацию, то есть для эффективного результата следует применять его с другими методиками оценки риска. Например, можно комбинировать с калькулятором CVSS, то есть сначала оценить уровень риска с помощью OWASP, а затем использовать результаты CVSS для

уточнения и приоритезации устранения уязвимостей.

Для более наглядного сравнения калькуляторов изобразим данные в виде таблицы 2.

Таблица 2– Сравнительный анализ калькуляторов

Калькулятор	Цель	Методология	Отличие от аналогов
CVSS	Оценка уязвимостей, с учетом временных факторов и контекста	Шкала от 0-10	Объективная оценка угроз
EPSS	Прогноз вероятности эксплуатации	Вероятность (0-100)	Использует обратный метод, основываясь на фактических результатах
OWASP	Оценка рисков для бизнеса	Вероятность × ущерб	Оценки рисков, на основе технических и бизнес-аспектов

CVSS, EPSS, OWASP [22-26] представляют собой ключевые инструменты в области кибербезопасности, поскольку каждый из которых решает свои задачи, но в совокупности обеспечивает более эффективное управление киберрисками. EPSS+CVSS помогают эффективно распределять ресурсы, сначала критичные – это CVSS и вероятные для атак EPSS. OWASP позволяет минимизировать появление уязвимостей на этапе проектирования и разработки, снижая нагрузку на эксплуатационные команды. Комбинация этих средств формирует комплексный подход к безопасности, который охватывает все меры защиты. Все вместе они формируют комплексную картину существующих угроз и позволяют специалистам по безопасности улучшить подготовку к возможным инцидентам. Объединение использование этих инструментов в единой структуре рисков значительно укрепит адаптивность систем безопасности.

2 Разработка методического обеспечения риск-моделирования кибератак

В современном мире, где технологии развиваются с стремительной скоростью, растет и вероятность возникновения новых киберугроз. Эти угрозы представляют серьезную опасность компаниям, государственным организациям и критически важным инфраструктурным объектам. Поэтому для защиты информации необходимо осуществлять эффективное управление рисками. Вместо того, чтобы просто реагировать на атаки, необходимо активно анализировать угрозы и прогнозировать их развитие. Современные системы информационной безопасности должны быть способны не только отражать известные атаки, но и адаптироваться к новым, непредсказуемым сценариям. Учитывая сложность и постоянное усовершенствование угроз, требуется комплексный подход позволяющий своевременно предотвращать атаки, основанный на моделировании и анализе рисков.

Одной из важнейших составляющих методического обеспечения является разработка методик оценки рисков для различных типов атак, таких как единичные, многовекторные комплексные атаки.

Эпоха единичных атак постепенно подходит к концу, тем самым открывается новая эпоха массированных компьютерных вторжений, направленных на автоматизированные системы. Сегодняшняя угроза представлена огромным числом различных типов атак. Такая ситуация и создает сложную многомерную проблему для специалистов по защите информации, которым необходимо одновременно бороться с множеством угроз. Каждый тип атак имеет свои особенности, которые влияют на выбор методов оценку последствий потенциальных угроз. Здесь задача осложняется тем, что отсутствуют эффективные инструменты и методы для полного анализа возникающих рисков и своевременного реагирования на массовые киберугрозы [9-48].

Настоящая разработка нацелена на создание современной методологии, позволяющей моделировать многовекторные кибератаки, что позволит специалистам по защите информации вовремя регулировать риски реализации многовекторых кибератак. Так как многовекторные атаки являются следующим этапом развития, то

они как никак построены на одиночных и не рассчитав их, невозможно будет рассчитать старшее звено в линейке развития. Особое внимание уделяется разработке математических моделей, которые позволят оценивать риски комбинированных атак и прогнозировать их потенциальный ущерб. Это требует объединения теории вероятности, системного анализа и машинного обучения, такой подход позволит не только оценивать риски, но и моделировать развитие атакующих методик в перспективе.

Реализация предлагаемого подхода позволит перейти и защиты отдельных фрагментов к созданию целостной системы кибербезопасности. Поскольку комплексное понимание многовекторных атак и их вероятностных характеристик может обеспечить эффективную защиту в будущем.

Таким образом, предлагаемая методология представляет собой значимый шаг в защите информационных систем. Её внедрение способно стать основой для нового поколения защитных систем, которые сочетают в себе адаптивность и способность противостоять изощренным атакам.

2.1 Методическое обеспечение моделирования рисков единичных кибератак

Современный ландшафт киберугроз характеризуется переходом от точенных ударов к масштабным вторжениям в защищенные системы. Даже небольшое количество атак, использующих множество уязвимостей, создает огромную проблему для специалистов по защите информации. Особенно остро стоит вопрос противодействия множественным атакам, при явном недостатке инструментов для их анализа и эффективной защиты. Решение этой проблемы требует разработки новых подходов к оценке и управлению рисками, связанными с массированными кибератаками, с учётом их многофакторности и динамики.

Модели единичной атаки обобщенно они представлены на рисунке 10, где рисунок 10а иллюстрирует действия злоумышленника по выбору на объекте атаки множества программных ошибок CVE. В свою очередь, рисунок 10б отражает поиск злоумышленником тех уязвимостей, которые обладают необходимой критичностью в

случае их эксплуатации избранным шаблоном атаки CAPEC. Модули процесса обеспечивают злоумышленнику отбор требуемой CAPEC уязвимости CVE (модуль коммутации), а также оценку P_j вероятности успешной её эксплуатации и получения ожидаемого ущерба u_j, исходя из возможностей ресурсов калькуляции CVSS и EPSS.

На следующем уровне детализации в модуль включаются техники (MITRE), которые реализуют соответствующие этапы вторжения уже для собственного набора уязвимостей.

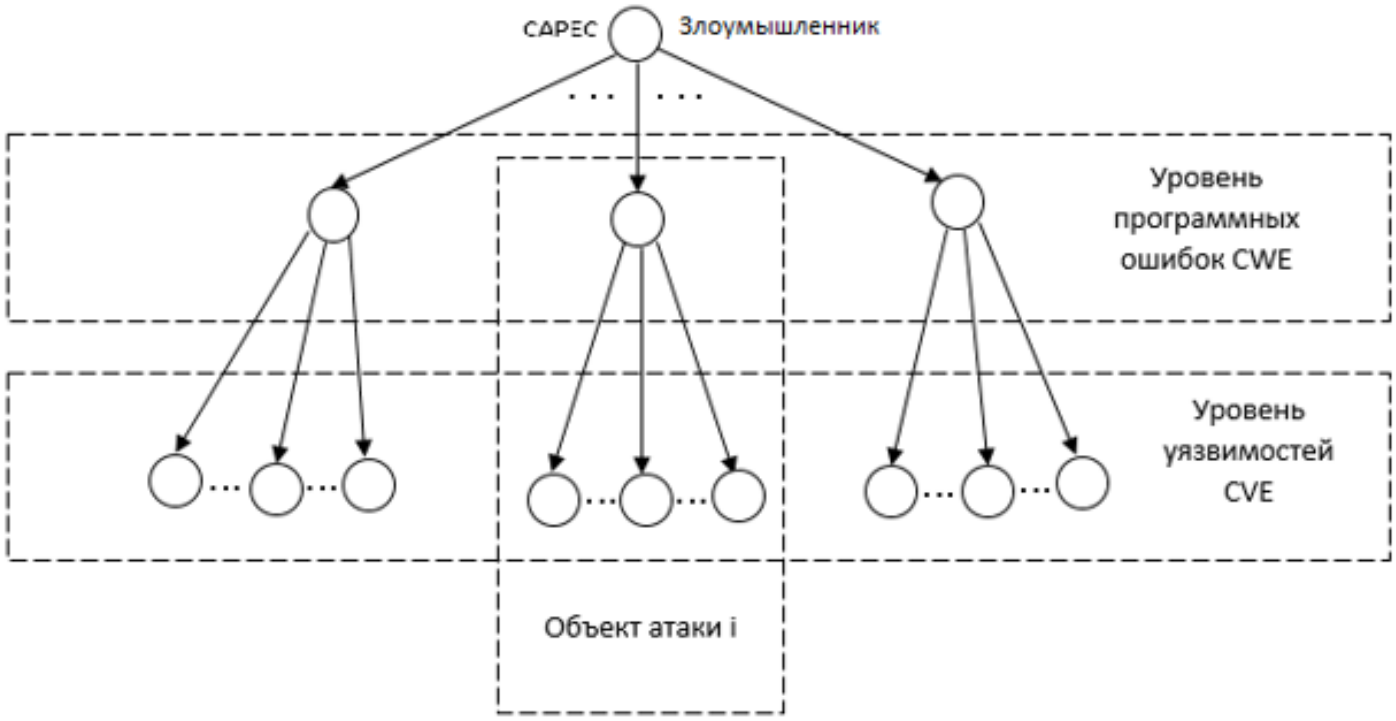


Рисунок 10а – Сценарий действий злоумышленника

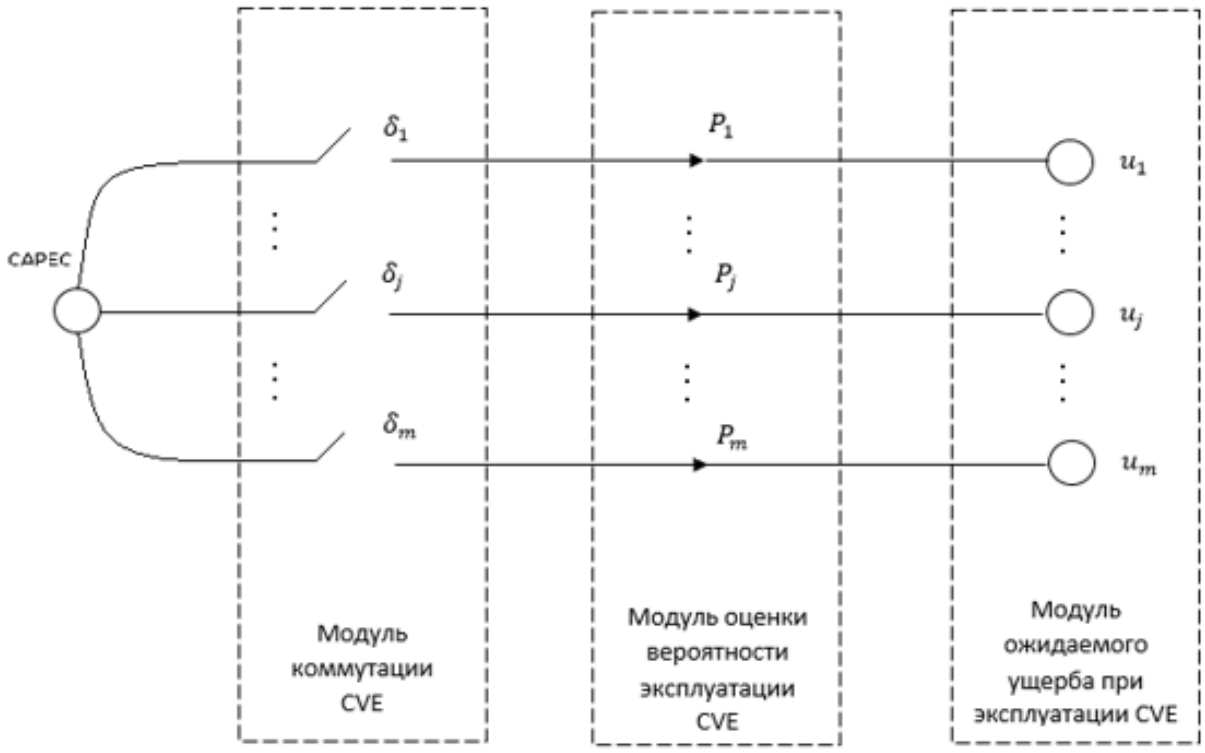


Рисунок 10б – Сценарий действий злоумышленника

Предложенные модели значительно повышают эффективность анализа и проектирования систем, тем самым обеспечивая универсальность подхода к управлению рисками в условиях постоянно меняющегося ландшафта угроз.

В соответствии с классификациями CAPEC и БД идентифицированы i-ый вектор атаки и эксплуатируемая j-ая уязвимость. Тогда рассматривается ситуация, когда i-ый вектор кибератаки пытается проэксплуатировать j-ую уязвимость. При этом известны CVSS-параметры и уязвимости и CAPEC данные вектора. Необходимо вычистить вероятность p_{ij} и ущерб u_{ij} успешной реализации данного единичного вторжения.

Переходя к расчету вероятности реализации единичных кибератак, устанавливается соответствие между вектором атаки и конкретной уязвимостью, им эксплуатируемой. Далее при наличии описания атакующих векторов и оценки критичности уязвимостей, стоится полная группа событий, представляющая собой конкретный путь реализации атаки, может быть рассчитана по формуле (1):

$$p_{ij} = \frac{K_{ij} * \delta_{ij}}{\sum_{k=1}^{m} K_{ij} * \delta_{ij}}, \quad (1)$$

где:

p_{ij} – вероятность того, что техника i будет реализована через уязвимость j,

K_j – критичность уязвимости j, определяемая из ресурса CVSS,

δ_{ij} – коэффициент, означающий возможность отбора рассматриваемых уязвимостей ($\delta_{ij} = 0$ при $\delta_{ij} = 1$) по критериям популярности эксплуатации уязвимости,

m – количество эксплуатируемых техникой i уязвимостей, определяется из ресурса EPSS.

Соответственно для каждой группы событий имеем:

$$\sum_{j=1}^{n} p_j = 1. \quad (2)$$

Вероятность использования прямопропорцианальна её критичности, поскольку каждая уязвимость доступна для эксплуатации и вызывает интерес киберпреступника. Критичность, в свою очередь учитывает ряд уникальных характеристик, присущих конкретной уязвимости.

Для выражения (1) дополнительную составляющую, которая уточнит вид ожидаемого ущерба внесёт коэффициент КЦД. Тогда будут возможны следующие варианты оценки риска, определяющиеся в зависимости от типа угрозы: нарушение конфиденциальности, целостности и доступности в ходе реализации атаки i-го вида на j-ую уязвимость. Таким образом, величину ущерба представляет возможным рассчитать по формуле (3):

$$u_{ij} = S * K_{CIA} = \frac{S(K_c + K_I + K_A)}{3}, \quad (3)$$

где:

u_{ij} – ущерб успешной атаки i-м вектором на j-ю уязвимость,

S – ценность ресурса, на который направленна атака,

K_{CIA} – коэффициент ущерба для каждого из 3 направлений (конфиденциальность, целостность, доступность) взятый из ресурса CVSS.

Для оценки рисков пар «вектор атаки – уязвимость» уместно следующее выражение [4]:

$$Risk_{ij} = p_{ij}u_{ij}, \quad (4)$$

где $Risk_{ij}$ – риск реализации сочетания i-го вектора атаки на j-й уязвимостью.

Тогда из формул (1) и (3), риск (4) определяется по следующей формуле:

$$Risk_{ij} = p_{ij}u_{ij} = \frac{K_{ij}*\delta_{ij}}{\sum_{k=1}^{m} K_{ij}*\delta_{ij}} * \mathrm{C}(K_c + K_I + K_A), \quad (5)$$

Формула (5) позволяет решить ситуацию, когда i-ый вектор кибератаки пытается проэксплуатировать j-ую уязвимость, соответственно представляется возможным проводить сравнительный анализ между парами «атака-уязвимость».

2.2 Методическое обеспечение для моделирования рисков многократных кибератак

Рассмотрев основы для расчета единичных атак, практический интерес все же вызывает рассмотрение многократных атак. Многократные атаки представляют собой действия злоумышленника предпринимающиеся несколько раз с одной и той же целью или разными целями. Они могут быть частью сложной кампании, направленной на проникновение в защищаемую систему.

Рассмотрим систему, подвергающуюся многократным атакам многовекторно, по её компонентам. Допустим, что требуется определить вероятность успеха k атак их

общего числа n, при этом учитывая возможный ущерб. Здесь обычно применяется биноминальное распределение вероятности [90]:

$$P(k,n,p) = C_n^k p^k (1-p)^{n-k}, \quad (6)$$

где:

k – ожидаемое количество успешных атак в отношении рассматриваемого компонента защищаемой системы;

n – реализуемое количество атак заданным злоумышленником шаблоном;

p – вероятность успеха единичной атаки компонента заданным шаблоном.

Пример вычисления вероятностей, согласно выражению (6), имеется в [90] для случая n=10, n различных значений p. Считая k величиной ущерба, здесь можно оценить риск:

$$Risk(k,n,p) = kC_n^k p^k (1-p)^{n-k}, \quad (7)$$

где k=1(1)10.

Для установленных в примере значений p=0,25;0,5;0,75, согласно выражению (7), были рассчитаны величины риска (рис. 11). Как видно из этого рисунка они значительно разнятся. Это говорит о том, что в рамках многокомпонентной системы (с различными вероятностями успеха единичной атаки её элементов) разброс значений рисков довольно значителен.

Вместе с тем, возможно реализовать управление с целью уравнивания этих рисков хотя бы по их максимальным величинам. Дело в том, что считать параметр k ущербом возможно только в том случае, если ценности информационного ресурса всякого компонента защищаемой системы равновелики. Однако такая ситуация, не учитывающая p, создает перекос в системы обеспечения безопасности (рис.11).

Отсюда ущерб в действительности равен kC_i, где C_i - ценность защищаемого ресурса i-ой компоненты. Следуя этому свойству, представляется возможным перераспределить ценность ресурса системы с учетом максимумов риска

компонентов, найденных без учёта этих ресурсов. К примеру, для рассматриваемого примера следует добиваться равенства:

$$max\{P_1 k_1 C_1\} = max\{P_2 k_2 C_2\} = max\{P_3 k_3 C_3\}\,, \tag{8}$$

В результате графики огибающих риска примут вид, представленный на рисунке 12. Отсюда суммарный риск, равный:

$$Risk_{\sum} = Risk_1 + Risk_2 + Risk_3. \tag{9}$$

дает соответствующий график огибающей (рис. 12). Он (с некоторой неравномерностью) имеет относительно неизменное значение, причем данная неравномерность, может быть, оптимизационно отрегулирована под нужный уровень вариаций параметров p_1, p_2 и p_3.

Приведенный пример для трех компонентов легко может быть обобщен для произвольного количества таковых, а суммарный риск в заданном диапазоне ущербов будет равномерен с необходимой неравномерностью.

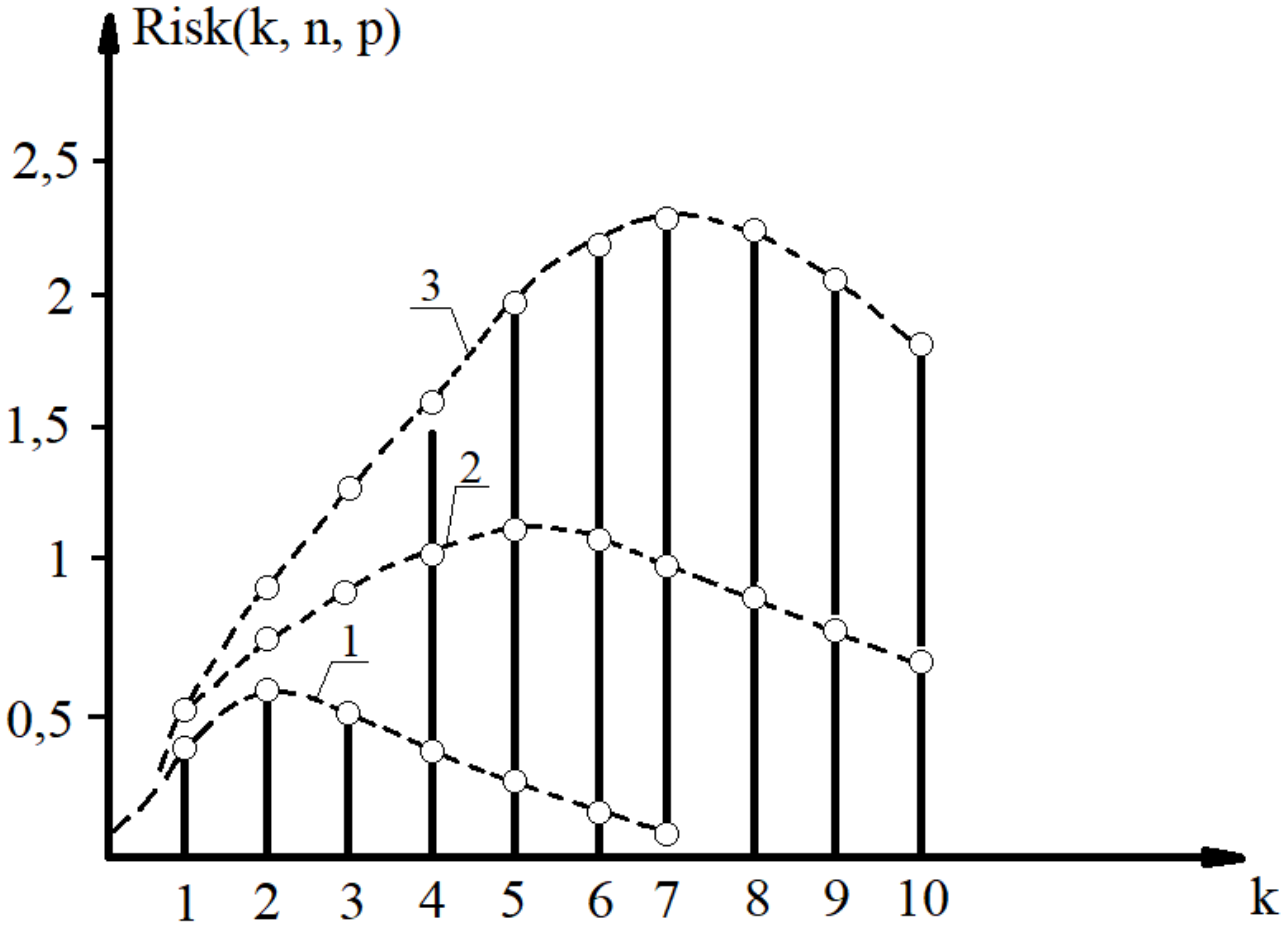


Рисунок 11 – Графики рисков компонентов атакуемой системы (огибающей риска первой 1, второй 2 и третьей 3 компоненты) от ущерба в виде количества успешных атак

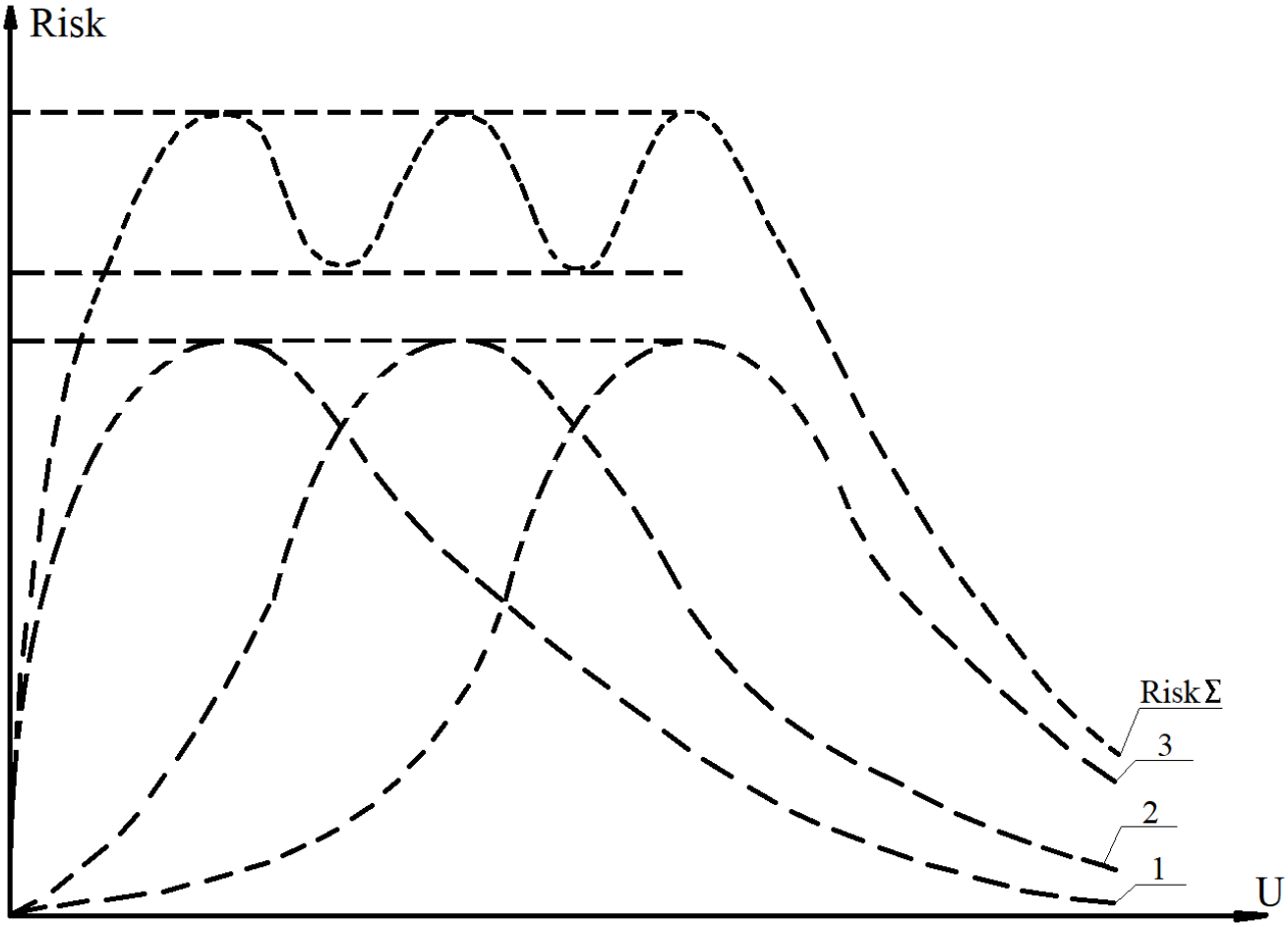


Рисунок 12 – Формирование функции суммарного риска и огибающих трех компонент системы от ущерба с учетом ценности охраняемого ресурса компонента.

Рассмотрим подробно управление рисками.

Вводя параметр C_i как ценность защищаемого ресурса i-ой компоненты, функция риска принимает следующий вид (10):

$$Risk(k, C_i, n, p) = k \cdot C_i \cdot C_n^k p^k (1-p)^{n-k} \qquad (10)$$

С учетом вводимых параметров ценности и вероятности успешной атаки, управление риском осуществляется с помощью квантильного метода перенормировки вероятностей, что позволит достичь условия равенства максимумов (9) для каждого слагаемого в сумме (9).

Управление представляет собой несколько этапов: перенормировка самих вероятностей, перерасчет рисков и выравнивание их с целью минимизации значений, удовлетворяющих условию (9). Для описания работы с множеством значений рисков и соответствующих им вероятностей для каждой уязвимости, удобно представлять эти величины через набор векторов, по которым можно ввести и осуществить операцию поиска максимумов и минимумов соответственно (11):

$$\max_{k} Risk_i(k)\,, \tag{11}$$

где через данное соотношение обозначается максимальная величина вычисленного риска для выбранной уязвимости (максимум из всех значений рисков для одной уязвимости).

Для заданного квантиля q необходимо вычислить число успешных атак $k_q^{(i)}$, которое покрывает q-тую долю биномиального распределения. Сделать это можно с помощью обратной функции распределения (12):

$$k_q^{(i)} = F^{-1}(q; n, p_i), \tag{12}$$

где:

$\mathrm{F}^{-1}(\mathrm{q};\mathrm{n},\mathrm{p_i})$ – обратная функция биномиального распределения;

$\mathrm{k_q^{(i)}}$ – количество успешных атак (будет достигнуто или превышено с вероятностью q для i-й уязвимости);

q – целевой квантиль.

Позиция целевого квантиля для i-й уязвимости $T(p_i)$ определяется как:

$$T(p_i) = c - \frac{w}{2} + w \cdot \frac{p_i - p_{min}}{p_{max} - p_{min}}, \tag{13}$$

где:

c – центр целевого интервала;

w – ширина целевого интервала;

p_{min} – минимальная исходная вероятность из списка всех уязвимостей;

p_{max} – максимальная исходная вероятность из списка всех уязвимостей.

На целевую позицию следует наложить условие ограничения значений вероятности, которое можно описать функцией $\theta(x)$, во избежание получения недопустимых значений (14):

$$\theta(x) = \max(0{,}05, \min(0{,}95, x)). \quad (14)$$

Поскольку функция поиска целевой позиции и количества успешных атак ($T(p_i)$ и $k_q^{(i)}$) монотонны, то справедливо заметить сохранение следующего неравенства (15) при выполнении операции перенормировки:

$$p_i < p_j \Longrightarrow p_i^* < p_j^*, \quad (15)$$

где p^* – перенормированное значение исходной вероятности с указанными параметрами.

Таким образом, соотношение для перераспределения по квантильному методу перенормировки (16) имеет вид:

$$p^* = T(p) \cdot \frac{F^{-1}(q; n, p)}{n \cdot q}. \quad (16)$$

Далее следует рассчитать значение рисков для перенормированных значений вероятности, после чего скорректировать их с целью достижения оптимального значения. Для описания скорректированного риска введем величину $Risk^*$ – результат воздействия некоторого отображения $\varphi : R \to R$, позволяющего достичь условия максимума (8). Поскольку суммарный оптимальный риск равен сумме оптимальных,

достаточно рассмотреть методику расчета $Risk^*$ для одного слагаемого, аналогичным образом применяя ее для каждого последующего для заданного набора исходных рисков.

Поскольку коррекция происходит в каждой точке распределения, то для описания отображения удобно представить риск в виде зависимости от k, опуская прочие параметры – отображение позволяет сохранить форму распределения при изменении начальных величин. Таким образом, φ представимо как (17):

$$\varphi\big(Risk(k)\big) = Risk(k)^* = Risk(k) \cdot \varepsilon\,, \tag{17}$$

где:

$Risk^*(k)$ – перенормированное значение риска,

$Risk(k)$ – значение начального риска для k успешных атак,

ε – некоторый коэффициент коррекции i-того значения

Также справедливо заметить, что для данное отображение в контексте рисков, сохраняет аргументы, при которых достигается максимум (18):

$$argmax_k\, Risk(k) = argmax_k\, Risk^*(k) \tag{18}$$

Для достижения управления введем функционал (19), выделяющий как метрику квадрат отклонений и ограничивающий чрезмерное отклонение корректирующих коэффициентов:

$$J(\varepsilon) = \sum_{i=1}^{m}\sum_{j=1}^{m}\Big(\varepsilon_i \cdot \max_k Risk_i(k) - \varepsilon_j \cdot \max_k Risk_j(k)\Big)^2 + \lambda \sum_{i=1}^{m}(\ln \varepsilon)^2 \tag{19}$$

Оптимальное управление риском достигается, если коэффициент коррекции обратно пропорционален пиковому значению (20), так как при таком значении коэффициента первое слагаемое функционала (19) обнуляется:

$$\varepsilon_i = \frac{\max\left(Risk(k)\right)}{\max\limits_{k} Risk_i(k)} \tag{20}$$

Таким образом достигается управление риском для множественных атак, позволяя, изменяя параметры для квантильной перенормировки вероятности, достичь оптимального значения суммарного риска, попадающего в ограниченный диапазон.

Возможна также проектная ситуация, когда система имеющая m уязвимостей, подвергается потоком из n атак (рис.13), одного шаблона.



Рисунок 13 – Система из уязвимостей, атакуемая потоком из n атак

В этом случае уместно применить мильтиномиальное распределение [90] вероятности:

$$P(x_1, \dots, x_m, n, p_1, \dots, p_m) = \frac{n!}{x_1! \dots x_m!} p_1^{x_1} \dots p_m^{x_m}, \quad (21)$$

где:

x_i= 0,1,2… и i=1(1)m;

$\sum_{i=1}^{m} x_i = n$; p_i – вероятность успешной эксплуатации i-ой уязвимости;

$\sum_{i=1}^{m} p_i = 1$; np_i – матожидание количества успешных атак на i-ую уязвимость.

Для выражения (21) суммарный ущерб от рассматриваемой атаки составит:

$$U_{\sum} = \sum_{i=1}^{m} x_i u_i, \quad (22)$$

где u_i - ущерб от единичной успешной атаки i-ой уязвимости.

С учетом вышеизложенного наиболее ожидаемый итог атаки имеет следующий риск:

$$Risk_{\sum} \quad ([np_1], \dots, [np_m], n, p_1, \dots, p_m) = (\sum_{i=1}^{m} x_i u_i) \times$$
$$\times P([np_1], \dots, [np_m], n, p_1, \dots, p_m), \quad (23)$$

где:

$[np_1]$ – часть np: при i=1(1)m.

Если предположить, что ущербы уязвимостей равновероятны, т.е. $u_i = u_0$ при i=1(1)m, то выражение (23) примет вид:

$$Risk_{\sum} = nu_0 \times \mathrm{P}([np_1], \dots, [np_m], n, p_1, \dots, p_m). \quad (24)$$

Кроме того, вероятность в выражении (21) может быть существенно упрощена (избавлена от факториалов) с помощью приближения Стерлинга [90]:

$$n! \approx \left(\frac{n}{e}\right)^n \sqrt{2\pi n} \left(1 + \frac{1}{12n} + \cdots\right), \quad (25)$$

что существенно сократит вычислительные затраты.

С точки зрения регулирования риска (23) представляется рациональным учесть ценность защищаемого ресурса C_i в каждом атакуемом компоненте системы i-ой уязвимостью:

$$u_i = \alpha_i C_i, \tag{26}$$

где α_i – доля ценности, утрачиваемая при каждой успешной эксплуатации i-ой уязвимости.

Если нам удастся распределить общий ресурс атакуемых компонент обратно пропорционально произведению $[np_1]\alpha_i$, то суммарный риск будет минимизирован.

Возможны и иные оптимизации риска, учитывающие прочие особенности модели. Например, изменяемость α_i по мере роста x_i, т.е. частоты успеха единичных атак и т.п. Однако здесь, видимо, придется применять численную оптимизацию.

При этом надо понимать, что поток атак (рис.13) может также носить стохастический характер, который может быть расписан распределением Пуассона [90]:

$$P(n, \lambda) = \frac{\lambda t}{n!} e^{-\lambda t}, \tag{27}$$

где: n – ожидаемое за время наблюдения t количества атак;

λ - интенсивность атак, которую удалось оценить на предыдущих периодах наблюдения потока.

Из выражения (23) и (27) вероятность совмещенных событий (появления потока атак) и их реализации будет равна:

$$P_{\sum} = P(n, \lambda) \times P(x_1, \dots, x_m, n, p_1, \dots, p_m). \tag{28}$$

Соответственно скорректируется и функция риска (24). Однако, следует понимать, что управление $P(n, \lambda)$ доступно лишь злоумышленнику через регулирование λ и для защитника атакуемой системы носит исключительно случайный характер. Поэтому лишь выражение $P(x_1, \dots, x_m, n, p_1, \dots, p_m)$ будет доступно ему для управления риском реализации атак.

Также во избежание переполнений при работе с большими степенями и значениями факториалов использовались логарифмические функции.

Логарифм факториала n:

$$\log(n!) = \Gamma(n+1), \tag{29}$$

где Γ – гамма-функция, обобщающая понятие факториала на комплексные и вещественные числа.

Сумма логарифмов факториалов x_i:

$$\sum \log(x_i!). \tag{30}$$

Сумма $x_i \log(p_i)$:

$$\sum x_i \log(p_i). \tag{31}$$

Итоговое значение вероятности вычисляется следующим образом (32):

$$\mathrm{P} = e^{\log(n!) - \sum \log(x_i!) + \sum x_i \log(p_i)}, \tag{32}$$

где e – экспоненциальная функция.

Следующий шаг – расчет риска:

$$Risk = (\sum_{i=1}^{m} x_i \, u_i) P(x_1, \dots, x_m), \tag{33}$$

где:

$u_i = \alpha C_i$ – ущерб от одной успешной атаки;

α – коэффициент потери ценности;

C_i – ценность ресурса.

Для реализации алгоритма работы использовались следующие формулы:

Нормировка вероятностей осуществляется с помощью (34) :

$$p_i^* = \frac{p_i}{\sum p_i}, \tag{34}$$

где p_i^* - нормированное значение вероятности.

Расчет ожидаемых успешных атак:

$$x_i \approx np_i^*. \tag{35}$$

Расчет ущерба осуществляется при помощи (26), тогда суммарный ущерб для исхода x (22)

Далее следует оптимизация ресурсов с целью минимизировать риск путем перенормировки C_i при фиксированной общей ценности $\sum C_i = C_\Sigma$.

Формула оптимальных C_i:

$$C_i' = C_\Sigma \frac{w_i}{\sum_{j=1}^{m} w_j}, \tag{36}$$

Где

$w_i = \frac{1}{np_i\alpha}$;

w_i – вес, необходим для оптимального распределения ресурсов в зависимости от значения p_i.

2.3 Методическое обеспечение для моделирования рисков многовекторных кибератак

Многовекторные атаки – это сложные киберугрозы, принципиально отличающиеся от обычных атак своей масштабностью гибкостью. Особенностью многовекторных атак являются тот факт, что они реализуются одновременно по нескольким объектом с использованием различных шаблонов атак, злоумышленник не ограничиваются одним способом, они комбинируют разные подходы, для обхода защиты. (рис. 14). Это делает такие атаки особенно опасными, поскольку специалистам приходится противостоять множеству угроз.

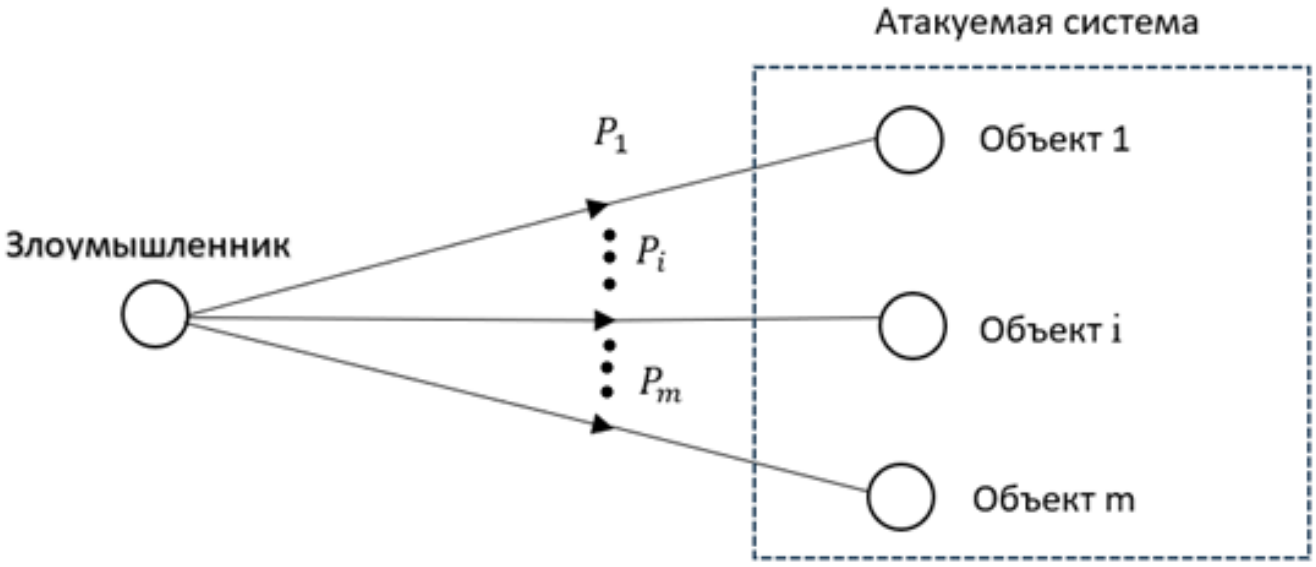


Рисунок 14 – Схема многовекторной атаки системы

Почему же многовекторные атаки эффективны? Зачастую системы защиты настроены на конкретные угрозы, а многовекторная атака обходит эти ограничения. Также, пока специалисты устраняют одну проблему, злоумышленники могут воспользоваться другими уязвимостями. И соответственно даже частичный успех от атаки может привести к компрометации данных.

Если предположить, что удалось вычислить вероятности успешной реализации каждого из использованных векторов $P_1 \dots \dots \dots . P_m$, то вероятность удачной атаки хотя

бы одним из них будет равна:

$$P = 1 - \prod_{i=1}^{m}(1 - P_i). \quad (37)$$

В этой формуле (37) учтены все возможные сочетания успешности векторов (одиночные, попарные и даже одновременно всех векторов атаки).

Отсюда риск возникновения подобной ситуации представляется оценить следующим выражением:

$$Risk_{\sum}=\sum_{i=1}^{m} P_i U_i + \sum_{i=1}^{m} P_i P_j (U_i + U_j) + \ldots + \prod_{i=1}^{m} P_i \sum_{i=1}^{m} u_i, \quad (38)$$

где:

$\sum_{i=1}^{m} P_i U_i$ - риск успешности единичных атак с ущербами, i=1(1)m

$\sum_{i=1}^{m} P_i P_j (U_i + U_j)$ – риск успешности всевозможных попарных сочетаний векторов с ущербами U_i и U_j, i, j=1(1)m и i≠j

$\prod_{i=1}^{m} P_i \sum_{i=1}^{m} u_i$ – риск успешной реализации всех рассматриваемых векторов атаки.

Разумеется, потребуется также оценка ожидаемых ущербов, наносимых каждому объекту атаки, $u_1, \ldots, u_i \ldots, u_j \ldots, u_m$

Следуя выражению (38), представляется возможным измерить риск для любого сочетания рассматриваемых векторов атак. В этом случае многовекторная атака становится комбинированной.

Разумеется, реализованные раньше алгоритмы и программы автоматизированного риск анализа [9] обретут второе дыхание в комплексе вышеописанного (37) и (38) моделирования кибератак (масштабно и относительно оригинально).

3 Сценарии рисков реализации киберугроз

3.1 Связь техника – уязвимость в процессе осуществления кибератак

В данном разделе исследуется взаимосвязь между техниками кибератак и эксплуатируемыми уязвимостями, с акцентом на детализацию сценариев атак через призму базы данных MITRE ATT&CK. Эта база позволяет разложить атаки на последовательности техник, соответствующих тактикам от разведки до воздействия, причём сценарии не всегда линейны — возможны циклы, например, повторное повышение привилегий через определённую технику. Важно отметить, что не все техники связаны с уязвимостями, как в случае техник разведки, а в рамках одной тактики злоумышленники могут выбирать разные техники, что усложняет анализ.

Ключевой задачей является разработка методики и её автоматизация для установления соответствия между техниками MITRE ATT&CK, эксплуатируемыми уязвимостями (CVE) и вероятностями успешной эксплуатации. Эта задача особенно актуальна для комплексных атак, сочетающих несколько сценариев, включая CAPEC-комбинированные атаки, а также для моделирования атак с оценкой их успешности на основе вероятностных моделей. Для прогнозирования успешности атаки предлагается построить микромодели эксплуатации уязвимостей для каждой техники, связать их в единый сценарий с помощью передаточных функций и оценить общую вероятность успеха, учитывая наиболее вероятные уязвимости на каждом этапе.

Помимо вероятностных оценок, важной задачей является оценка ущерба, для чего предлагается нормировать его по ценности защищаемого ресурса, что позволяет абстрагироваться от конкретики и сравнивать различные атаки. Учёт специфики эксплуатации уязвимостей даёт более точные оценки потенциального ущерба.

Перспективным направлением является формализация противодействия кибератакам, включая автоматизацию моделирования атак и разработки мер реагирования. Использование MITRE ATT&CK позволяет строить вероятностные микромодели для каждой тактики, интегрируя риск-калькуляторы для количественных оценок. Это даёт возможность прогнозировать траектории

комплексных атак, оценивая их успешность через вероятности эксплуатации уязвимостей на каждом этапе. Такой подход способствует более точному моделированию кибератак, оценке их рисков и разработке эффективных мер защиты, что особенно важно в условиях роста сложности и масштабов современных киберугроз.

3.2 Сценарии реализуемых техник кибератак

В сценарном туннеле реализуемых техник имеет место перемножение вероятностей их реализации, которые представляют собой дискретную функцию ущерба, наносимого атакуемой системе эксплуатацией всякой уязвимости соответствующей рассматриваемой техники (рис. 15)

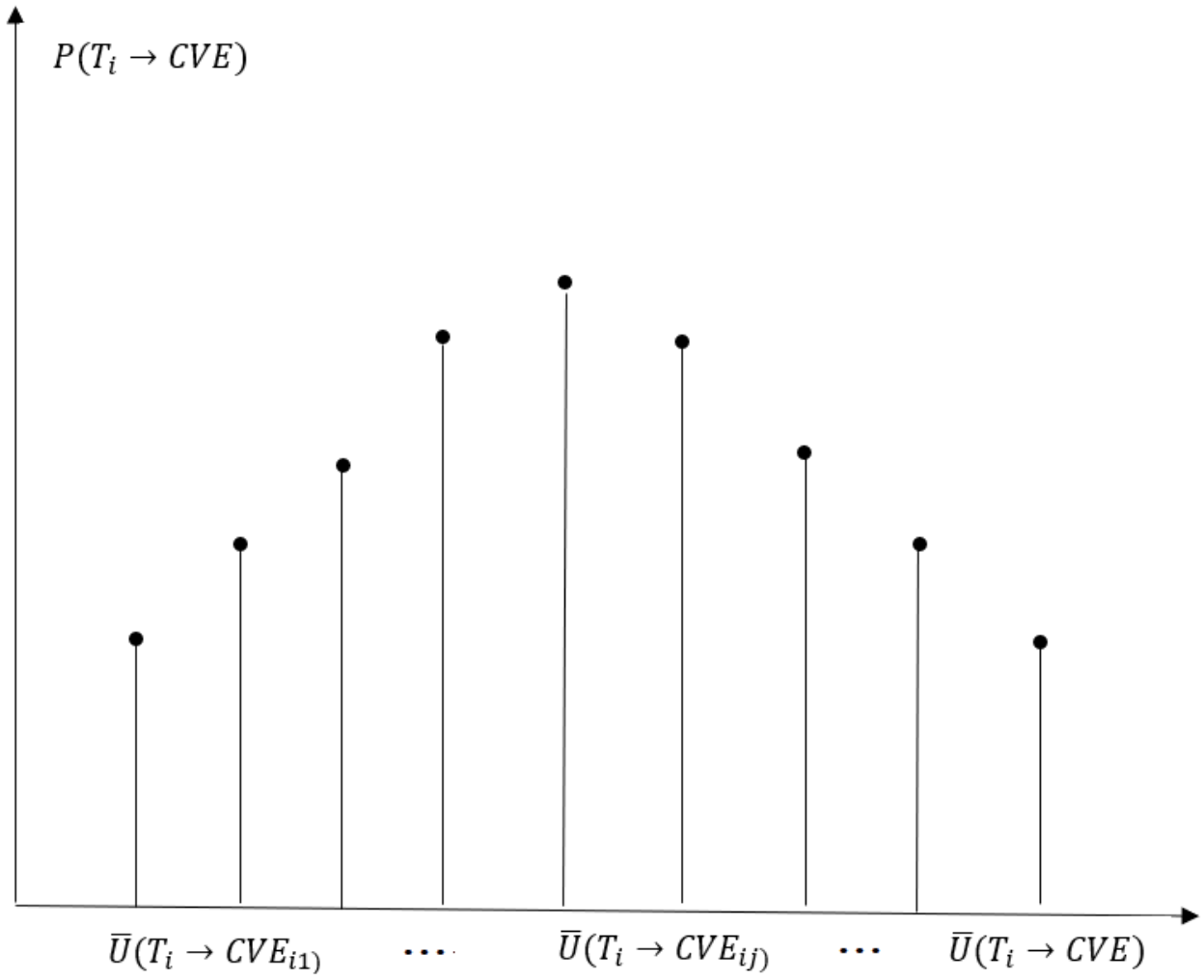


Рисунок 15 – Распределение вероятности реализации i-ой техники сценария

Следует заметить, что нормируемый ущерб в данном случае (рис. 15) рассчитывается в виде:

$$\overline{U}\left(T_i \rightarrow CVE_{ij}\right) = \frac{CVSS\left(CVE_{ij}\right) * K_{CISA\ KEV}(CVE_{ij})}{35}, \quad (39)$$

где:

$CVSS\left(CVE_{ij}\right)$ – параметр ущерба для уязвимости CVE_{ij} согласно ресурсу CVSS;

$K_{CISA\ KEV}(CVE_{ij})$ – поправка на популярность эксплуатации уязвимости CVE_{ij} согласно ресурсу CISA KEV.

При этом вероятность реализации всего сценария очевидно будет равна:

$$P_{\text{сценр.}} = \prod_{i=1}^{k} P(T_i \rightarrow CVE_{ij}), \quad (40)$$

где:

k – количество используемых в сценарии техник.

В свою очередь $P\left(T_i \rightarrow CVE_{ij}\right)$, при j=1(1)m, где m количество эксплуатируемых техникой i уязвимостей, определяется из ресурса EPSS и/или критичности K_{ij} вышеописанных уязвимостей из ресурса CVSS:

$$P\left(T_i \rightarrow CVE_{ij}\right) = \frac{K_{ij} * \delta_{ij}}{\sum_{j=1}^{m} K_{ij} * \delta_{ij}}, \quad (41)$$

имея ввиду, что внимание злоумышленника, прежде всего привлечёт небольшая из них. В выражении (41) коэффициент δ_{ij} обозначает возможность отбора рассматриваемых уязвимостей ($\delta_{ij} = 0$ при $\delta_{ij} = 1$) по критериям популярности эксплуатации уязвимости и/или наличия таковой в конкретно рассматриваемой системе.

Что же касается суммарного ущерба, то он очевидно будет складываться из суммы ущербов (39) отдельно эксплуатируемых уязвимостей по техникам:

$$\overline{U}_{\text{сценар.}} = \sum_{i=1}^{k} \overline{U}\left(T_i \rightarrow CVE_{ij}\right). \quad (42)$$

Соответственно из выражений (40) и (42) сценарный риск можно вычислить следующим образом:

$$Risk_{\text{сценар}} = P_{\text{сценарн}} * \overline{U}_{\text{сценар}}. \quad (43)$$

Что же касается управления риском (43), то в отличие от многовекторных атак, где дело приходится иметь с суммой рисков реализации каждого атакуемого объекта, то в данном туннелировании сценария (рис. 15) следует реализовывать произведение вероятностей (рис. 16)

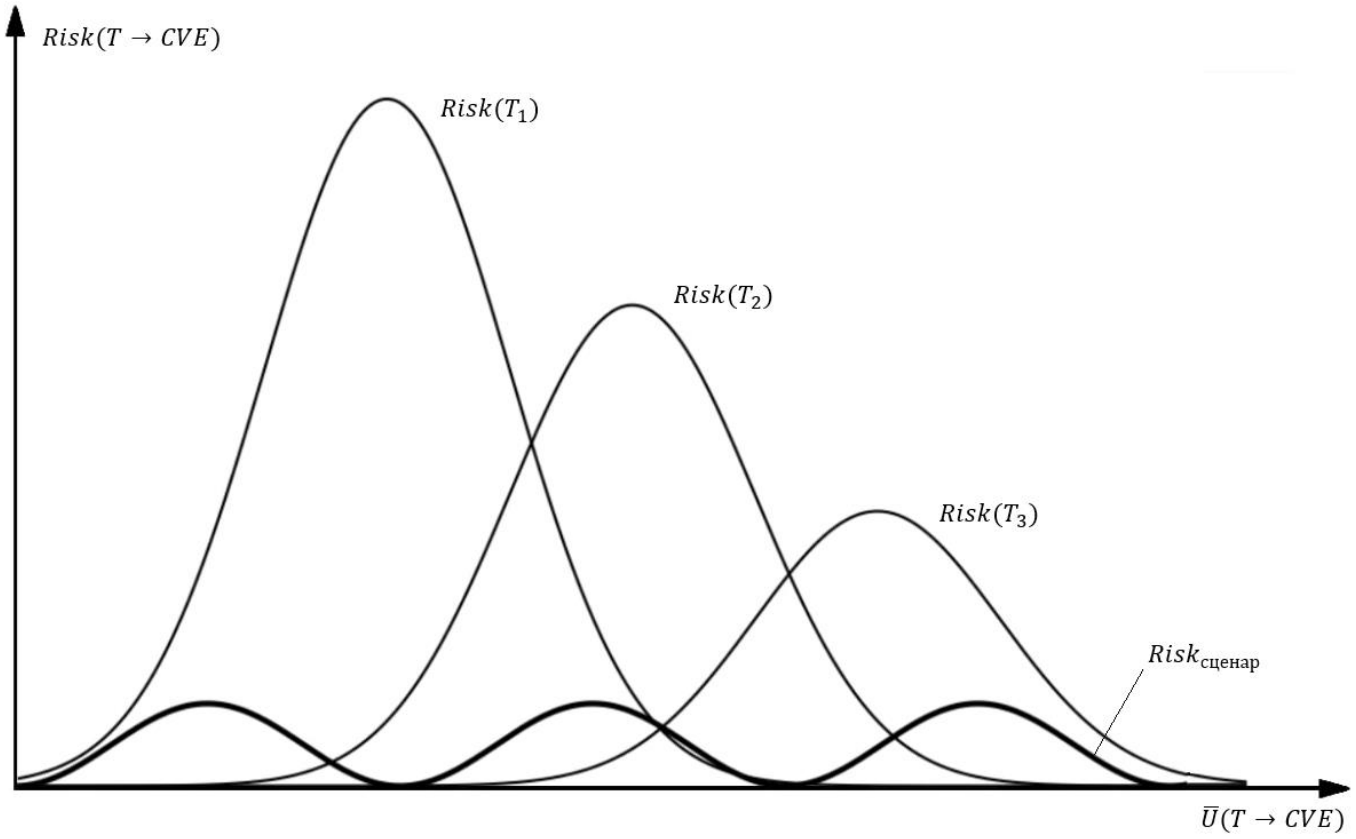


Рисунок 16 – Графики огибающих риска для реализации отдельных трех техник и сценария в целом

Графики на рисунках 15 и 16 иллюстрируют распределение вероятности реализации рисков, демонстрируя, как отдельные техники и их комбинации влияют на общий риск. Особенностью управления риском в данном контексте является необходимость учёта учета произведений вероятностей, что отличает их от многовекторных, где риски суммируются. Предложенный подход позволяет системно оценивать угрозы и принимать обоснованные решения по снижению риска, фокусируясь на наиболее критичных и вероятных векторах атаки.

3.3 Перспективные направления управления рисками современных кибератак

Эффективное управление рисками, довольно-таки важная задача, поскольку за последнее десятилетие киберпреступники значительно усовершенствовали свои методы и инструменты, что серьезно затрудняет работы специалистов по обеспечению защиты. Особую тревогу вызывает тенденция к сложным и скоординированным кибератакам, где отдельные инциденты являются частями тщательно разработанных многоступенчатых операций. Методы оценки и управления рисками, которые основаны на статистике и экспертных оценках, зачастую оказываются неэффективными в стремительно разевающейся среде киберугроз [].

Современные системы управления рисками сталкиваются с проблемами информационного, методического и технического обеспечения, которые требуют инновационных решений. Основной проблемой выступает быстрая обработка больших объемов данных. Важно выявлять сложные взаимосвязи и закономерности развития кибератак. Другая не менее важная проблема это увеличение времени между обнаружением угрозы и принятием мер защиты, потому что это представляет опасность, при использовании злоумышленниками инструментов для массовых атак.

Будущее систем управления рисками, должно основываться на нескольких ключевых принципах. Прежде всего, это необходимость перехода от реагирования на инциденты к прогнозированию кибератак, при этом анализируя сложные сценарии и предлагать оптимальные стратегии реагирования. При этом необходимо уделять особое внимание результатам анализа, они должны быть простыми и понятными,

поскольку в условиях ограниченного времени для принятия решений важна наглядность и обоснованность рекомендаций.

Технологии распределённого реестра и блокчейна открывают новые возможности для развития систем управления рисками, тем самым обеспечивая повышенное доверие и ясность при происходящем обмене информацией об угрозах между организациями. Это особенно актуально в условиях сложности цепочек поставок и увеличения использования сторонних серверов. Разработка стандартизированных протоколов обмена данными об угрозах позволит создать эффективные механизмы безопасности, обеспечивая при этом оперативное распространение информации об обнаруженных атаках среди потенциальных жертв.

Управление рисками в условиях развития технологий таких как квантовые вычисления, интернет вещей (IoT) и искусственного интеллекта, требует нового подхода. Эти технологии помимо своих преимуществ, порождают новые угрозы, ранее неизвестные, и требующие специализированных методов оценки и противодействия. Ключевым фактором является их адаптивность, потому что существующие нормативные акты и методы защиты постоянно усовершенствуются. Необходимы гибкие стандарты, ориентированные на достижение определенного уровня безопасности. Эффективное управление рисками требует комплексного подхода, которой будет объединять передовые технологии, актуальную нормативную базу и квалифицированных специалистов. Будущие решения должны быть основаны на интегрированных платформах, которые используют искусственный интеллект для анализа угроз и автоматизацию реагирования, тем самым обеспечивая непрерывную защиту.

Заключение

В рамках выпускной квалификационной работы удалось создать информационные и методическое обеспечение для оценки и управления рисков кибератак направленных на автоматизированные информационные системы.

Перспективой исследования множественных атак следует считать изучение комплексных кибервторжений. Сегодня криминальные группировки и спецслужбы враждующих государств всё чаще приобретают именно к этому инструменту информационной борьбы, где сценарные сюрпризы ожидают администраторов атакуемых систем и сетей по ходу реализации операции и за счёт гибридизации и варьирования набором средств атаки по ходу противоборства. Рваный тем вторжения, адаптируемого в зависимости от его промежуточных результатов, может демонстрировать как одиночные атаки, так и их «ливень». Искусство злоумышленника, а точнее группировки (время хакеров – одиночек давно прошло) будет проявляться именно в этом. Поэтому многотрудное моделирование комплексных атак все же необходимо осуществлять и результаты настоящей работы могут стать для него необходимым подспорьем, особенно с применением технологий искусственного интеллекта.

Новизна полученных результатов заключается в том, что:

- предложенное информационное методическое обеспечение, технического комплекса риск-моделирования, в отличии от существующих аналогов описывает методы автоматизированной оценки риска единичных, многократных и многовекторных кибератак, а также метрики для их калькуляции;

- впервые предлагается методика управления рисками для множественных кибератак в защищаемых автоматизированных системах, доведенная до автоматизации;

Практическая ценность полученных результатов видится в том, что

- разработанное информационное обеспечение, представляет сформированную базу данных, которая в полной мере служит основой для анализа кибератак;

- разработанное методическое обеспечение риск-моделирования, позволяют

значительно повысить устойчивость автоматизированных информационных систем к кибератакам, обеспечивая более точное прогнозирование и предотвращение потенциальных угроз;

- разработанный программно-технический комплекс может стать основой для формирования единых стандартов в области риск-моделирования кибератак, что облегчит внедрение и использование аналогичных решений в различных отраслях.

Теоретическая значимость результатов просматривается в том, что:

- полученные результаты включают в себя разработку технологических моделей и алгоритмов, которые могут послужить основой для дальнейшего научного изучения и совершенствования технологий риск-моделирования

- работа закладывает фундамент для последующих исследований в области автоматизации процессов оценки и прогнозирования киберугроз, открывая перспективы для более глубокого понимания и борьбы с кибератаками технологий риск-моделирования

- результаты исследования обогащают методологическую базу кибербезопасности, предоставляя новые принципы и методы для анализа и оценки рисков, что способствует повышению качества научных исследований и образовательных программ в этой области.

Таким образом, данная работа вносит существенный вклад в развитие методов защиты автоматизированных систем от современных угроз. Предложенные подходы не только улучшают защищённость информационных систем, но и способствуют формированию новых научно-практических направлений в области кибербезопасности. Результаты работы могут быть полезны как для специалистов по защите информации, так и для разработчиков защищенных автоматизированных систем.

Список литературы

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сете-вых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 Автоматизированный атлас кибератак/ Г.А. Остапенко, А.П. Васильченко, А.О. Калашников и др.; под ред. Академика РАН Д.А. Новикова. – М.: Горячая линия – Телеком, 2025. -188с. (Серия «Теория сетевых войн»; вып. 9). – Текст: непосред-ственный.

10 CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

11 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

12 MITRE ATT&CK (Positive Technologies). – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

13 MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

14 MITRE ATLAS. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/– Текст: электронный.

15 MITRE ATLAS (ФБИТ ИТМО). – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/– Текст: электронный.

16 CVE. – Электрон. дан. – Режим доступа: https://cve.mitre.org/. – Текст: электронный.

17 CWE - Common Weakness Enumeration. – Электрон. дан. – Режим досту-па: https://cwe.mitre.org/index.html. – Текст: электронный.

18 Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat.– Текст: электронный.

19 НКЦКИ. – Электрон. дан. – Режим доступа: https://cert.gov.ru/ – Текст: электронный.

20 CISA KEV. – Электрон. дан. – Режим доступа: https://www.cisa.gov/known-exploited-vulnerabilities-catalog– Текст: электронный.

21 NIST NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

22 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

23 Общая система оценки уязвимостей (CVSS). – Электрон. дан. – Режим доступа: https://www.first.org/cvss/specificationdocument. – Текст: электронный.

24 Common Vulnerability Scoring System v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/. – Текст: электронный.

25 Common Vulnerability Scoring System v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/. – Текст: электронный.

26 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-risk-rating.com/. – Текст: электронный.

27 SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

28 The Vulnerability Impact Scoring System (VISS). – Электрон. дан. – Режим доступа: https://viss.zoom.com/specifications#2-metrics. – Текст: электронный.

29 VISS калькулятор. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/0.07#VISS:0.07:PLI:NA/ICI:N/III:N/IAI:N/ITN:NA/STN:NA/DTN:NA/TIM:N/DCI:N/DII:N/DAI:N/DCL:N/UCI:NA – Текст: электронный.

30 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

31 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

32 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

33 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность.

2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

34 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. – Т.26. Вып. 3. - С. 447-454. – Текст: непосредственный.

35 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т.26. Вып. 4. - С. 579-586. – Текст: непосредственный.

36 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

37 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 235-246. – Текст: непосредственный.

38 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

39 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

40 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст:

непосредственный.

41 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230. – Текст: непосредственный.

42 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30. – Текст: непосредственный.

43 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т.26 Вып. 2. С. 261-276. – Текст: непосредственный.

44 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54. – Текст: непосредственный.

45 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336. – Текст: непосредственный.

46 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378. – Текст: непосредственный.

47 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024.

Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

48 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

49 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106. – Текст: непосредственный.

50 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128. – Текст: непосредственный.

51 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. – Текст: непосредственный.

52 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. – Текст: непосредственный.

53 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298. – Текст: непосредственный.

65 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. С.159-178. – Текст: непосредственный.

53 Архипова К.В. Автоматизированная информационная система моделирования эпидемических процессов, порожденных саморазмножающимися и мутирующими вредоносами / К.В. Архипова, А.А. Остапенко, В.В. Сафронова, В.Ю. Остапенко, Ю.Г. Пастернак // Информация и безопасность. 2022. Т. 25. № 3. С. 349-366. – Текст: непосредственный.

54 Остапенко Г.А. Киберполигон как проект управления информационными рисками / Г.А. Остапенко, В.И. Белоножкин, А.А. Остапенко, М.Е. Волкова // Информация и безопасность. 2023. Т. 26. № 1. С. 9-16. – Текст: непосредственный.

55 Остапенко Г.А. Разработка архитектуры киберполигона для повышения качества и результативности учебного процесса в исследовании атак на информационные системы и сети / Г.А. Остапенко, С.С. Куликов, А.В. Коноплин, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. № 1. С. 101-108. – Текст: непосредственный.

56 Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. Т. 26. №2. С. 169-176. – Текст: непосредственный.

57 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта "безопасный интернет" / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын // Информация и безопасность. 2021. Т. 24. № 2. С. 287-296. – Текст: непосредственный.

58 Сердечный А.Л. Метод информационно-картографического анализа активности группировок хактивистов / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. № 4. С. 587-596.

59 Остапенко А.Г. Сетевая вирусология: прогнозирование развития двувирусных эпидемических процессов в сетях. / А.Г. Остапенко, Е.В. Зарочинцев, О.А. Остапенко, К.В. Сибирко, В.В. Сафронова, П.Д. Федоров. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 203-222. – Текст: непосредственный.

60 Остапенко А.Г. Картографические модели процессов диффузии вредоносов

в сетевом киберпространстве. / А.Г. Остапенко, А.Л. Сердечный, А.А. Остапенко, С.С. Куликов. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 281-286. – Текст: непосредственный.

61 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта «Безопасный интернет». / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 287-296. – Текст: непосредственный.

62 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 55-66. – Текст: непосредственный.
76 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 67-80. – Текст: непосредственный.

63 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т.27. Вып. 1. С. 81-90. – Текст: непосредственный.

64 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246. – Текст: непосредственный.

65 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 91-98. – Текст: непосредственный.

66 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М.Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 99-108. – Текст: непосредственный.

67 Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 117-124. – Текст: непосредственный.

68 Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков// Информация и безопасность. 2024. Т. 27. Вып. 1. С. 135-142. – Текст: непосредственный.

69 Александров А.Г. Анализ угроз информационной безопасности при использовании облачных сервисов / А.Г. Александров, А.Ю. Петухов, М.Ю. Рытов // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 143-151. – Текст: непосредственный.

70 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 185-196. – Текст: непосредственный.

71 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 197-208. – Текст: непосредственный.

72 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю. Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 209-218. – Текст: непосредственный.

73 Сердечный А.Л. Информационное картографирование Blockchain-транзакций киберпреступников в экосистеме TON / А.Л. Сердечный, А.О. Абрамов, Е.А. Москалева // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 257-272. – Текст: непосредственный.

74 Громов Ю.Ю. Изучение возможности виртуализации технических средств защиты объектов с применением имитационного моделирования / Ю.Ю. Громов, П.И.

Карасев, Ф.М. Пыршев // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 379-388. – Текст: непосредственный.

75 Подтопельный В.В. Исследование специфики моделирования компьютерных атак с использованием марковских процессов принятий решений и Q- обучения / В.В. Подтопельный // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 421-440. – Текст: непосредственный.

76 Зорин В.А. Информационная безопасность и нейробиология социальной инженерии: когнитивные искажения, эмпатия / В.А. Зорин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 441-448. – Текст: непосредственный.

77 Зимницкий А.Г. Программно-технический комплекс выявления субъектов с повышенным риском девиантного поведения / А.Г. Зимницкий, А.А Остапенко // Информация и безопасность. 2022. Т. 25. № 4. С. 571-582. – Текст: непосредственный.

92 Сердечный А.Л. Информационная карта киберконфликта"палестина- израиль" / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т.26. № 4. С. 519-534. – Текст: непосредственный.

78 Остапенко А.Г. Целеполагание проектной деятельности по созданию инструментария автоматизированного выявления и риск-анализа деструктивных контентов, аффилированных с персоналом корпораций / А.Г. Остапенко, И.А, Боков, С.В. Лихобабин, Д.С. Ясенко, Е.Ю. Чапурин // Информация и безопасность. 2023. Т.26. № 4. С. 465-494. – Текст: непосредственный

79 Остапенко Г.А Формализация знаний и данных кибератак и уязвимостей/Г.А Остапенко, А.П. Васильченко, А.А Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин// Информация и безопасность. 2025 Т.27. №2 С 231-238. – Текст: непосредственный

80 Reducing the Significant Risk of Known Exploited Vulnerabilities – Электрон. дан. – Режим доступа: https://www.cisa.gov/known-exploited-vulnerabilities– Текст: электронный.

81 Анализ угроз безопасности по итогам 2024 года – Электрон. дан. – Режим доступа: https://www.securitycode.ru/company/blog/analiz-ugroz-bezopasnosti-po-itogam-2024-goda/– Текст: электронный.

82 Оценка уязвимостей CVSS 3.0 – Электрон. дан. – Режим доступа: https://habr.com/ru/companies/pt/articles/266485/– Текст: электронный.

83 Общая система оценки уязвимостей v3.1: Документ со спецификацией – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3-1/specification-document– Текст: электронный.

84 Тенденции развития киберугроз и методы их преодоления– Электрон. дан. – Режим доступа: https://na-journal.ru/4-2024-informacionnye-tekhnologii/10779-tendencii-razvitiya-kiberugroz-i-metody-ih-preod– Текст: электронный.

85 Основы кибербезопасности – Электрон. дан. – Режим доступа: https://iro23.ru/wpcontent/uploads/2023/02/%D0%9E%D1%81%D0%BD%D0%BE%D0%B2%D1%8B%D0%BA%D0%B8%D0%B1%D0%B5%D1%80%D0%B1%D0%B5%D0%B7%D0%BE%D0%BF%D0%B0%D1%81%D0%BD%D0%BE%D1%81%D1%82%D0%B8.pdf– Текст: электронный.

86 Развитие методов обнаружения угроз в системах информационной безопасности – Электрон. дан. – Режим доступа: https://na-journal.ru/3-2024-informacionnye-tekhnologii/9820-razvitie-metodov-obnaruzheniya-ugroz-v-sistemah-informacionnoj-bezopasnosti?ysclid=mc6l5ioznm371908025– Текст: электронный.

87 ГОСТ Р 58142-2018 Информационная технология. Методы и средства обеспечения безопасности. – Электрон. дан. – Режим доступа https://rosgosts.ru/file/gost/35/020/gost_r_581422018.pdf?ysclid=mcbn1t1a8z981786748– Текст: электронный.

88 Банк данных угроз безопасности информации– Электрон. дан. – Режим доступа:https://data-sec.ru/personal-data/threatsdatabank/?ysclid=mcbnjpe4sr360241696– Текст: электронный.

89 CVE news – Электрон. дан. – Режим доступа: https://www.cve.org/Media/News/item/blog/2025/03/11/CNA-Enrichment-Recognition-List-Update – Текст: электронный.

90 Сигорский В.П. Математический аппарат инженера. – К: Техника, 1977 – 768с. – Текст: непосредственный.

ПРИЛОЖЕНИЕ А

Глоссарий

Кибератака – момент решительных, координированных и преднамеренных действий злоумышленника по нанесению ущерба атакуемой кибернетической системе.

Угроза – совокупность условий и факторов, создающих опасность возникновения ущерба в системе;

Ущерб – вред, нанесенный системе при реализации угрозы;

Уязвимость – параметр, характеризующий возможность нанесения описываемой системе повреждений любой природы теми или иными внешними средствами или факторами;

Критичность – интегральный параметр, характеризующий степень сложности эксплуатации уязвимости и потенциальный ущерб от ее эксплуатации;

Единичная атака – это действия злоумышленника, направленные на эксплуатацию одной конкретной уязвимости в защищаемой системе с использованием одного вида атакующего воздействия;

Множественная атака – совокупность атакующих действий злоумышленника, которые неоднократно реализуются в отношении защищаемой системы;

Распределение – математическая модель вероятностей, используемая для оценки успешности атак;

Частота – параметр, показывающий, насколько часто в единицу времени используется определенный вид атаки при эксплуатации заданной уязвимости.